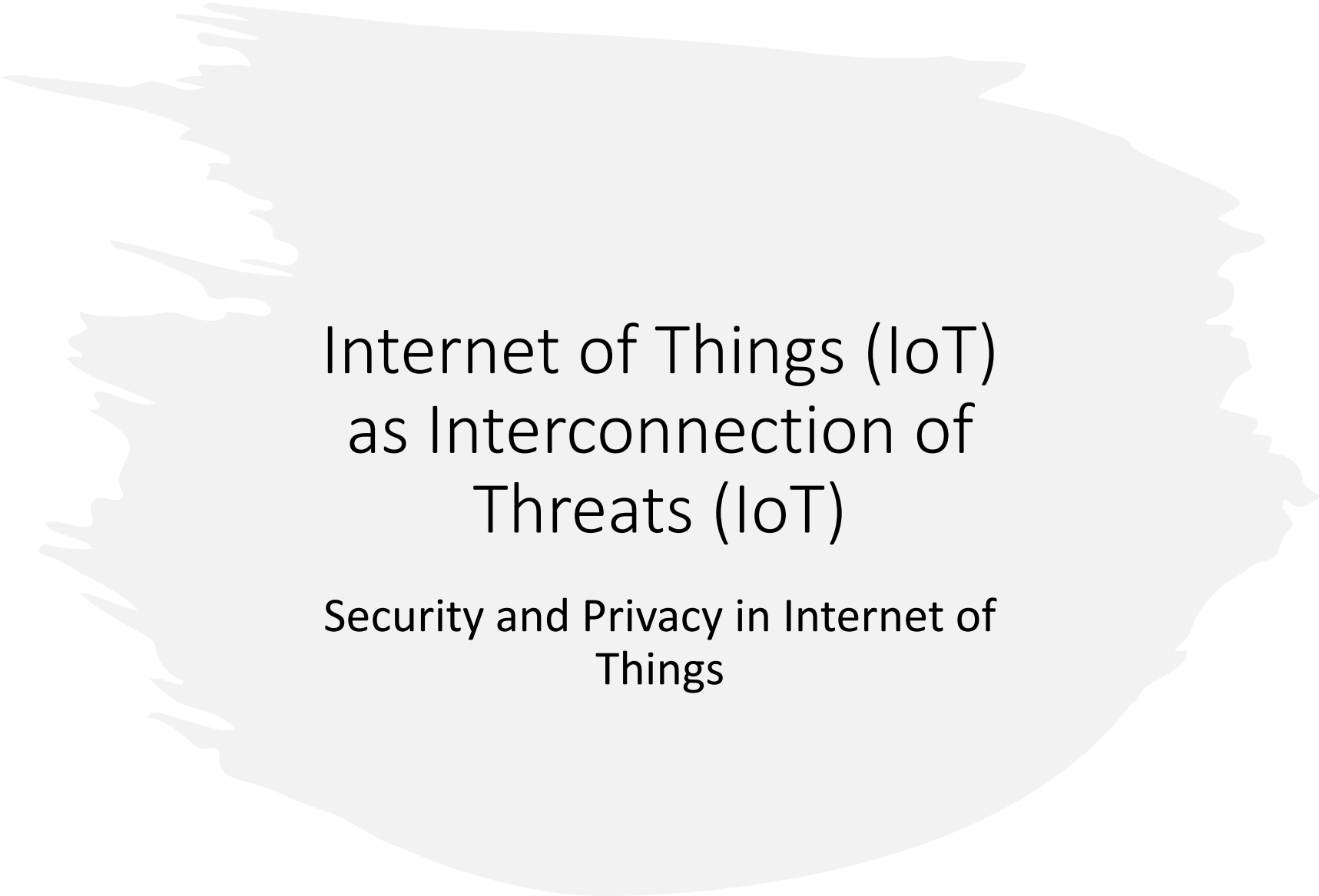


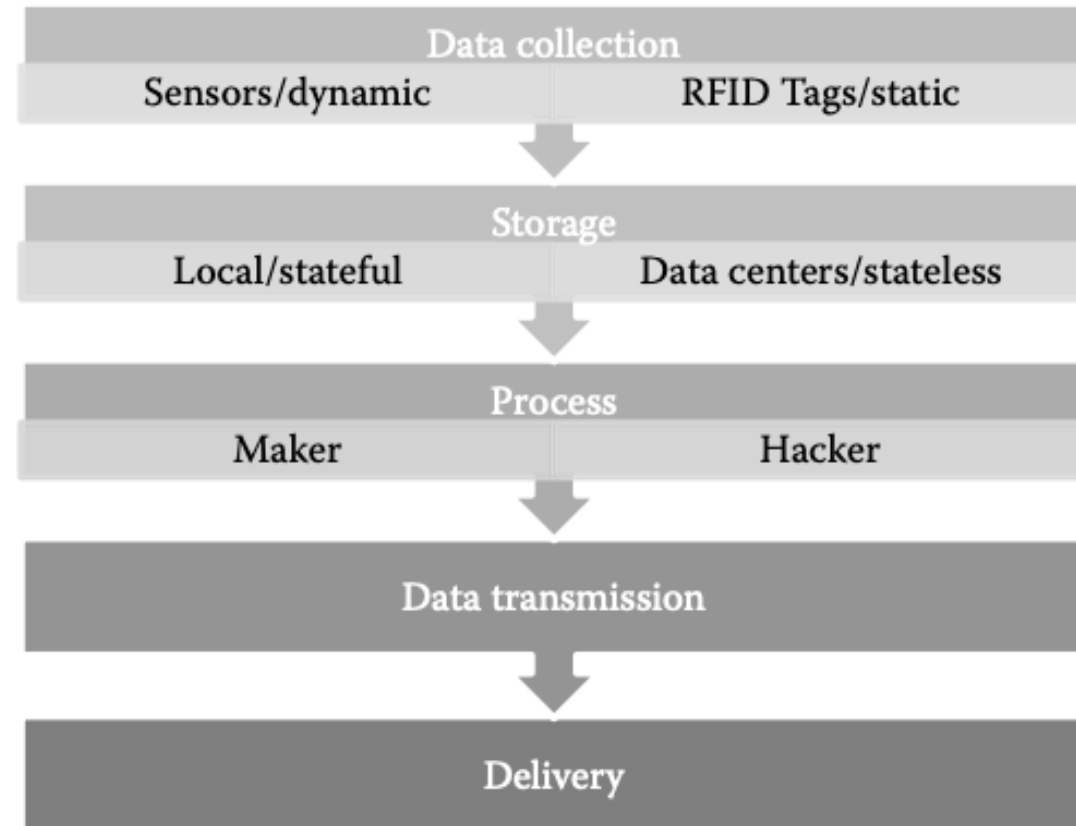


Internet of Things (IoT) as Interconnection of Threats (IoT)

Security and Privacy in Internet of
Things

Phase of IoT System

- The IoT requires five phases, from data collection to data delivery to the end users on or off demand.



Phase I: Data collection, acquisition, perception

- Collect or acquire data from the devices or things.
- Based on the characteristics of the thing, different types of data collectors are used
- The thing may be a static body (body sensors or RFID tags) or a dynamic vehicle (sensors and chips).

Phase II: Storage

- The data collected in phase I should be stored.
- If the thing has its own local memory, data can be stored.
- Generally, IoT components are installed with low memory and low processing capabilities.
- The cloud takes over the responsibility for storing the data in the case of stateless devices.

Phase III: Intelligent processing

- The IoT analyses the data stored in the cloud Data Center (DC)s and provides intelligent services for work and life in hard real time.
- As well as analysing and responding to queries, the IoT also controls things.
- There is no discrimination between a boot and a bot; the IoT offers intelligent processing and control services to all things equally.

Phase IV: Data transmission

Data transmission occurs in all phases:

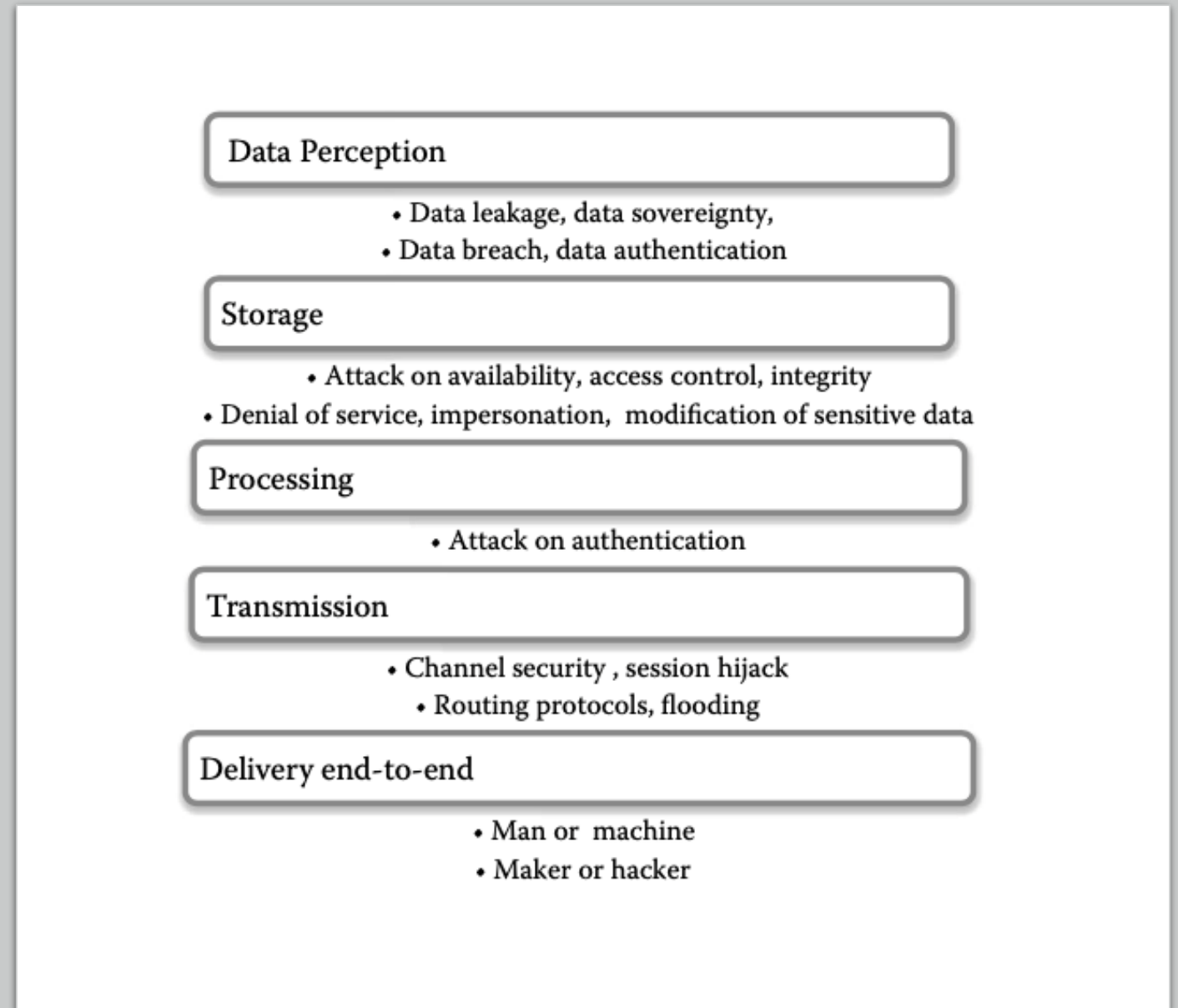
- From sensors, RFID tags, or chips to DCs
- From DCs to processing units
- From processors to controllers, devices, or end users

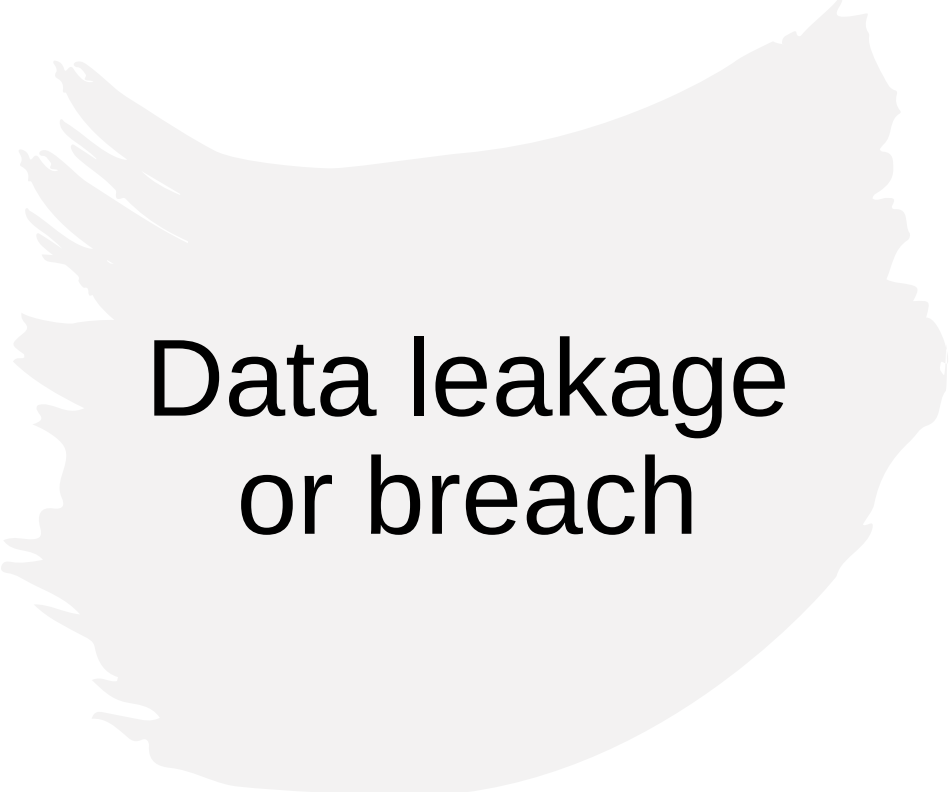
Phase V: Delivery

- Delivery of processed data to things on time without errors or alteration is a sensitive task that must always be carried out.

Phase attacks

- The Figure demonstrates the variety of attacks on the five phases of IoT.
- Data leakage, sovereignty, breach, and authentication are the major concerns in the data perception phase.





Data leakage or breach

- Data leakage can be internal or external, intentional or unintentional, authorized or malicious, involving hardware or software.
- Export of unauthorized data or information to an unintended destination is data leakage.
- Generally, this is done by a dishonest or dissatisfied employee of an organization.
- **Data leakage is a serious threat to reliability.**
- As the cloud data move from one tenant to several other tenants of the cloud, there is a serious risk of data leakage.
- The severity of data leakage can be reduced by the use of DLP (data leakage prevention).



How Data Leakage Happened

- Weak Security practices, since many IOT devices prioritize convenience over security (Weak Encryption, default configuration, default password).
- Different vulnerabilities exploited by attackers, by exploiting the weakness in the network protocols for the purpose of malicious activities.
- Accidental Actions, maybe the data- breaches done based on accidental leaks, such as human errors, misconfiguration for devices, or accidental sharing information can expose sensitive information.



Consequence of Data Leakage

- Privacy breaches, personal information such as home habits in smart home systems, or health data can be leakage in smart health systems can be exposed.
- Disrupted operations, since data breaches in industrial IOT system can disrupted the line of production for some factories and can do physical harm.



Countermeasures for Data Leakage

- Implement strong encryption algorithm for the data at the rest, to make it unreadable for the unauthorized users.
- Regular security update, based on discovered vulnerabilities, the system administrator can deal with all vulnerabilities.
- Strong Authentication techniques, such as depending on challenge response technique, or MFA.
- Segment network, by isolating IOT device on separate network, to minimize the effect in case breaches or leakage.
- Data Minimization, by only collect and deal with necessary data.
- Awareness as important point to learn the employee and users how to deal with IoT Devices and others.

Data sovereignty

- Data sovereignty means that information stored in digital form is subject to the laws of the country.
- The IoT encompasses all things across the globe and is hence liable to sovereignty.



Data Loss

- Data loss differs from data leakage in that the latter is a sort of revenge-taking activity on the employer or administrator.
- Data loss is losing the work accidentally due to hardware or software failure and natural disasters.



DATA LEAKAGE

Unauthorized exposure of data
to outside parties



What it is: Data is accessed or disclosed by someone who is not allowed to see it.



Example: Customer data is emailed to the wrong person or accessed by a hacker.



Intent: Usually caused by human error, poor security, or malicious activity.



Impact: Loss of confidentiality, privacy breach, legal and reputational damage.

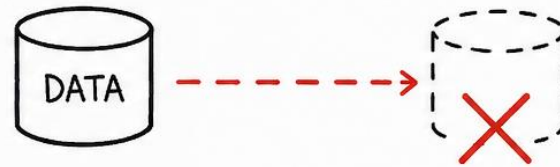


Focus: Prevent unauthorized access and sharing.

VS.

DATA LOSS

Unintentional or accidental
disappearance of data



What it is: Data is lost, deleted, corrupted, or becomes inaccessible.



Example: Important files are accidentally deleted or a hard drive crashes.



Intent: Usually unintentional or accidental (not meant to share).



Impact: Loss of availability, business disruption, financial loss.



Focus: Backup, recovery, and ensuring data availability.

Data Authentication

- Data can be perceived from any device at any time.
- Devices can be forged by intruders.
- It must be ensured that perceived data are received from intended or legitimate users only.
- It is mandatory to verify that the data have not been altered during transit.
- Data authentication could provide integrity and originality.

Why Data Authentication Important

- Sensor data, sensing data from devices such as industrial equipment or any other environment needs to be accurate to ensure about the collected data, and to build the right decision based on sensed data.
- Control commands, the commands that sent to the actuators or IOT devices, such as adjusting settings for specific machine or thermostat, we need to make sure that the commands haven't been modified or tampered with during transmission.
- Regarding to originality, the detection of spoofing attacks can be one of goals for originality, since the source of traffic to make sure that it comes from legitimate source.
- To achieve these points as example MAC (Message Authentication code) can be used here. $MAC = H(\text{Message} + \text{Shared Key})$. Or using Asymmetric Encryption.

Considerations about IOT-Authentication

- Standardization, IOT lacks a single, universal authentication standard. This fragmentation can make securing devices in IOT environment more and more complex.
- Scalability, the solution that must be found in IOT for the purpose of authentication must be scalable to handle a potentially vast number of devices.
- Resource constraints, since many of IOT devices have a limited processing power and memory. Authentication process need these IOT device to be efficient to avoid impacting device performance.

Attacks on Availability

- Availability is one of the primary securities for the intended clients.
- Distributed denial of service (DDoS) is an overload condition that is caused by a huge number of distributed attackers.
- But this not the only overload condition that makes the DCs unavailable to their intended clients.
- The varieties of overload threat occurrence that cause DCs to freeze at malicious traffic are analysed here:
 - Flooding by attackers
 - Flooding by legitimates (flash crowd)
 - Flooding by spoofing
 - Flooding by aggressive legitimates

Main Types of Spoofing

Spoofing means the attacker pretends to be someone/something else by using fake information.

1) IP Based Spoofing (Fake IP Address)

Attacker forges the source IP address in IP packet to hide identity or launch attacks.

How it works (Example – Ping Flood)

- 1 Attacker sends ICMP echo requests with a fake source IP (victim or any other IP).
- 2 Target (server) receives the request and replies to the fake IP.
- 3 The real source (spoofed IP owner) receives many replies and gets flooded.
- 4 Target may also become unreachable due to high load.



Why it is used

- Hide attacker's real identity
- Bypass IP based filtering
- Launch DoS/DDoS attacks (e.g., Ping Flood, SYN Flood)
- Scan networks anonymously

How IoT can be the source

- Many IoT devices have weak security and can be compromised.
- Attackers control many devices (botnet).
- Compromised IoT devices send spoofed packets at high rate.
- Always-on devices with high bandwidth (e.g., IP cameras, routers) are perfect for attacks.

Examples of IoT devices used

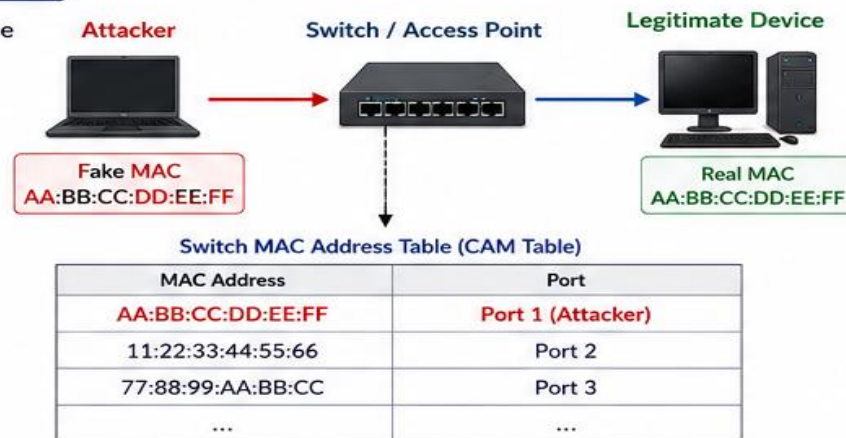


2) MAC Based Spoofing (Fake MAC Address)

Attacker changes the MAC address of their device to impersonate another device.

How it works (Example)

- 1 Attacker changes their device MAC address to that of a trusted device.
- 2 Network devices (switch/router) think attacker is the trusted device.
- 3 Attacker can bypass MAC filtering, steal session, intercept traffic, or do other attacks.



Why it is used

- Bypass MAC address filtering (e.g., in Wi-Fi or switches)
- Hijack connection / session
- Perform Man-in-the-Middle (MitM) attacks
- Access restricted network

How IoT can be the source

- IoT devices often use default credentials and weak firmware.
- Once compromised, attackers change MAC address.
- IoT devices stay connected 24/7, ideal for long-term attacks.
- Used to infiltrate networks and perform internal attacks.

Examples of IoT devices used



Key Takeaway

- **IP Spoofing** = Fake IP address (Layer 3) – used for hiding identity, DoS/DDoS.
- **MAC Spoofing** = Fake MAC address (Layer 2) – used for impersonation, bypassing controls.

Good Practices (to prevent)

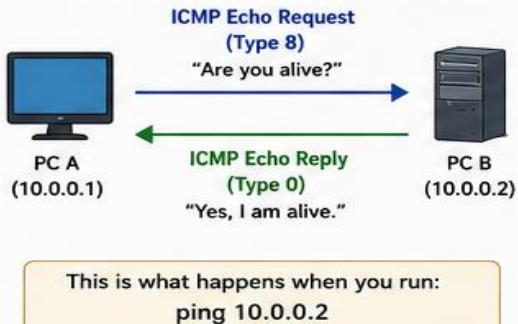
- Use ingress/egress filtering (BCP 38) to block spoofed IPs.
- Enable port security, MAC filtering, and 802.1X authentication.
- Keep IoT firmware updated and change default credentials.
- Monitor network traffic for abnormal patterns.

ICMP SPOOFING (PING FLOOD) ATTACK USING IoT DEVICES

1 WHAT IS ICMP?

ICMP (Internet Control Message Protocol) is used by network devices to send control messages and diagnostics, not for transferring data.

Example: Ping



2 WHY IoT DEVICES CAN BE USED?

- IoT devices are always connected
- Weak passwords and poor security
- Rarely updated
- Easy to compromise
- Millions of devices on the Internet

Examples of IoT devices:



After compromising thousands of IoT devices, attackers create a **BOTNET** that can be controlled remotely.

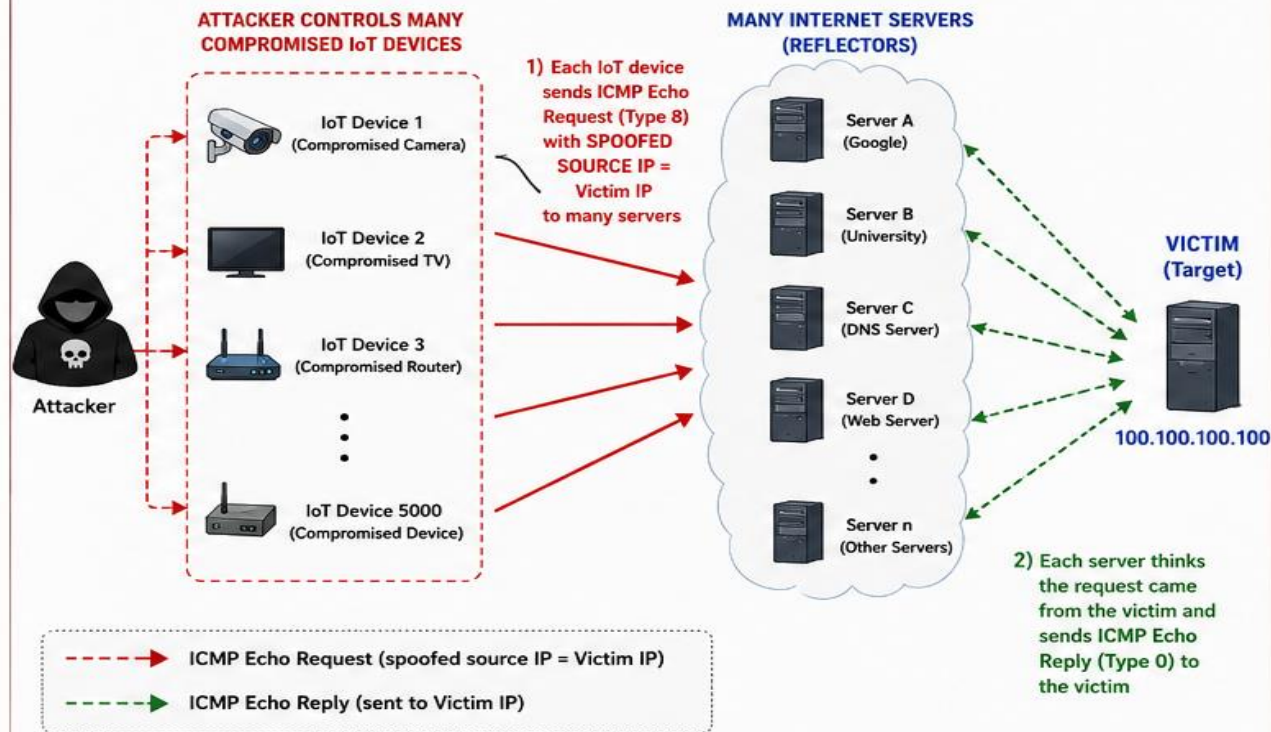
3 CAN ANY DEVICE SEND ICMP?

- ✓ Almost all IP-enabled devices can generate ICMP packets.
- ✓ Examples: PCs, Servers, Routers, Cameras, Smart TVs, Smartphones
- ✓ Some firewalls or administrators may block ICMP.
- ✓ The problem: IoT devices usually leave ICMP fully enabled and are easy to compromise at scale.

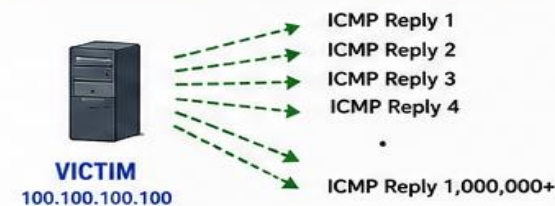
4 WHAT IS IP SPOOFING?



5 HOW DOES ICMP SPOOFING (PING FLOOD) ATTACK WORK?



6 WHAT HAPPENS TO THE VICTIM?



The victim never asked for these replies.

As a result:

- Network bandwidth is consumed
- CPU is overloaded
- Memory is consumed
- Services become slow
- Eventually the system becomes unavailable

This is a Denial of Service (DoS) attack.



KEY POINTS

1. Attacker compromises thousands of IoT devices and creates a botnet.

2. Each IoT device sends ICMP Echo Requests with spoofed source IP (victim IP) to many servers.

3. Many servers reply to the victim because they think the request came from the victim.

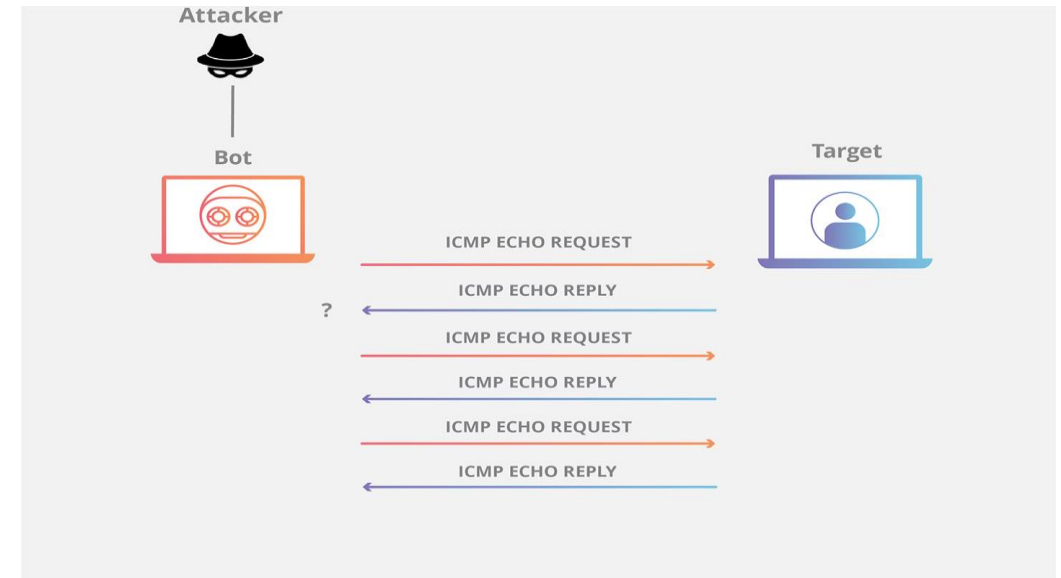
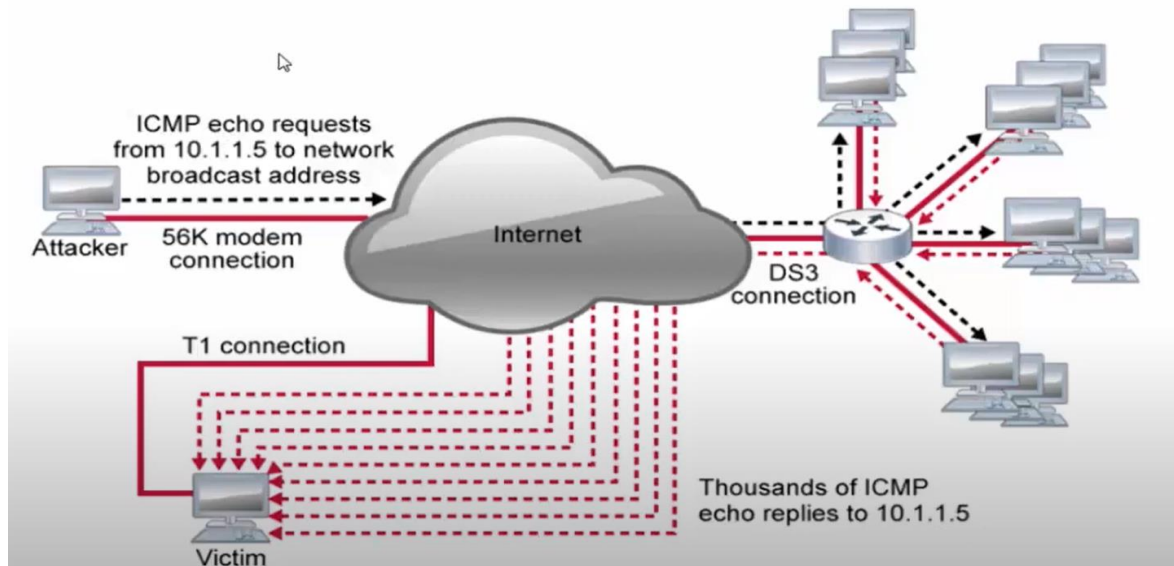
4. The victim is flooded with huge number of ICMP replies and cannot handle the traffic.

5. Service becomes slow and eventually unavailable.



Spoofing by Attacker

- ICMP Spoofing Attack, A ping flood is a denial-of-service attack in which the attacker attempts to overwhelm a targeted device with ICMP echo-request packets, causing the target to become inaccessible to normal traffic. When the attack traffic comes from multiple devices, the attack becomes a DDoS or distributed denial-of-service attack. This type of attack can consume both outgoing and incoming bandwidth.



UDP FLOOD (SPOOFING) ATTACK – SIMPLE EXPLANATION

1. What is it?

- A UDP Flood is a type of Denial-of-Service (DoS) attack.
- The attacker sends a huge number of UDP packets to the victim.
- The source IP address is spoofed (fake) as the victim's IP.
- The goal is to overwhelm the victim with traffic so it cannot respond to legitimate users.

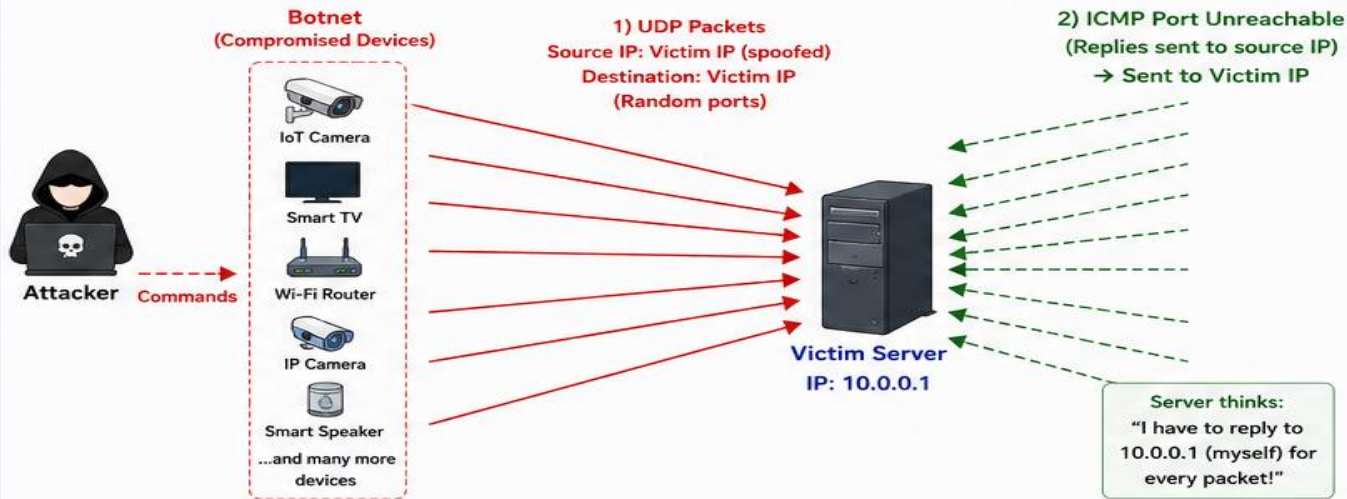
2. Key Point About UDP

- UDP is a connectionless protocol.
- When a server receives a UDP packet on a port where no application is listening, it still has to process it.
- It then sends back an ICMP "Port Unreachable" message to the source IP.
- If the source IP is spoofed as the victim, all those ICMP replies go to the victim.

3. How It Works (Step-by-Step)

- 1 Attacker controls many devices (botnet).
- 2 Each device sends UDP packets to random ports on the victim. Source IP = Victim IP (spoofed)
- 3 Victim receives the UDP packets.
- 4 For each packet, victim checks the port. Since no service is listening, victim sends an ICMP Port Unreachable message back to the "source" IP.
- 5 Because the source IP is spoofed (victim's IP), the victim sends thousands of ICMP replies to itself.
- 6 These replies consume bandwidth and resources → Victim becomes slow or completely down.

4. Visual Flow of UDP Flood Attack



5. Real-Life Scenario (Example)

Let's say a website is hosted on a server:

Website Server
IP: 10.0.0.1

Attacker's Plan:

- Attacker compromises 10,000 IoT devices.
- Each device sends UDP packets to random ports on 10.0.0.1.
- Source IP in each packet is set to 10.0.0.1 (spoofed).

What happens?

1	IoT Device sends UDP packet to 10.0.0.1 (port 54321)		→	Source IP = 10.0.0.1
2	Server checks port 54321 → No service running		→ X	No application
3	Server sends ICMP "Port Unreachable" to source IP (10.0.0.1)		→	ICMP Port Unreachable 
4	This happens thousands of times per second			
5	Server sends thousands of replies to itself		→	Bandwidth full CPU busy Service Down

6. Simple Analogy

Imagine someone keeps knocking on your door from many people (10,000 people).



You open the door, find nobody you know, and say: "I don't know you!"



Then you reply to each person saying "Go away!"



After some time, you are so busy replying that you cannot do anything else. This is what happens to the server.

7. Impact

-  Consumes bandwidth
-  High CPU usage
-  Memory exhaustion
-  Legitimate users cannot access the service
-  Website/Server becomes slow or unavailable

8. How to Defend (Basic Ideas)

-  Enable rate limiting on firewall/router
-  Drop spoofed packets (BCP 38 / uRPF)
-  Use IDS/IPS to detect abnormal traffic
-  Use DDoS protection service / CDN
-  Close unnecessary ports

Key Takeaway

In UDP Flood (Spoofing) attack, attacker sends many UDP packets with fake source IP (victim's IP).

Victim replies to itself with ICMP messages and gets overloaded, causing Denial of Service.



WHY CAN'T WE JUST DROP PACKETS WHEN SOURCE IP = DESTINATION IP?

1. LEGITIMATE SELF-COMMUNICATION IS NORMAL

Systems and applications sometimes send packets to themselves.

2. THE IP LAYER CANNOT KNOW THE INTENT

It only sees addresses, not whether the source IP was forged.

3. ATTACK TRAFFIC LOOKS IDENTICAL TO LEGITIMATE TRAFFIC

Both genuine and spoofed packets can have the same source and destination IP.

4. PROTOCOLS FOLLOW THEIR STANDARD BEHAVIOR

UDP and ICMP work as designed; the victim must reply to invalid requests.

COUNTERMEASURES

1. INGRESS FILTERING (BCP38)

Routers drop packets with source IPs that are not allowed to come from that network.

2. ANTI-SPOOFING RULES

Firewalls can drop packets where source IP = destination IP if they come from outside.

3. ICMP RATE LIMITING

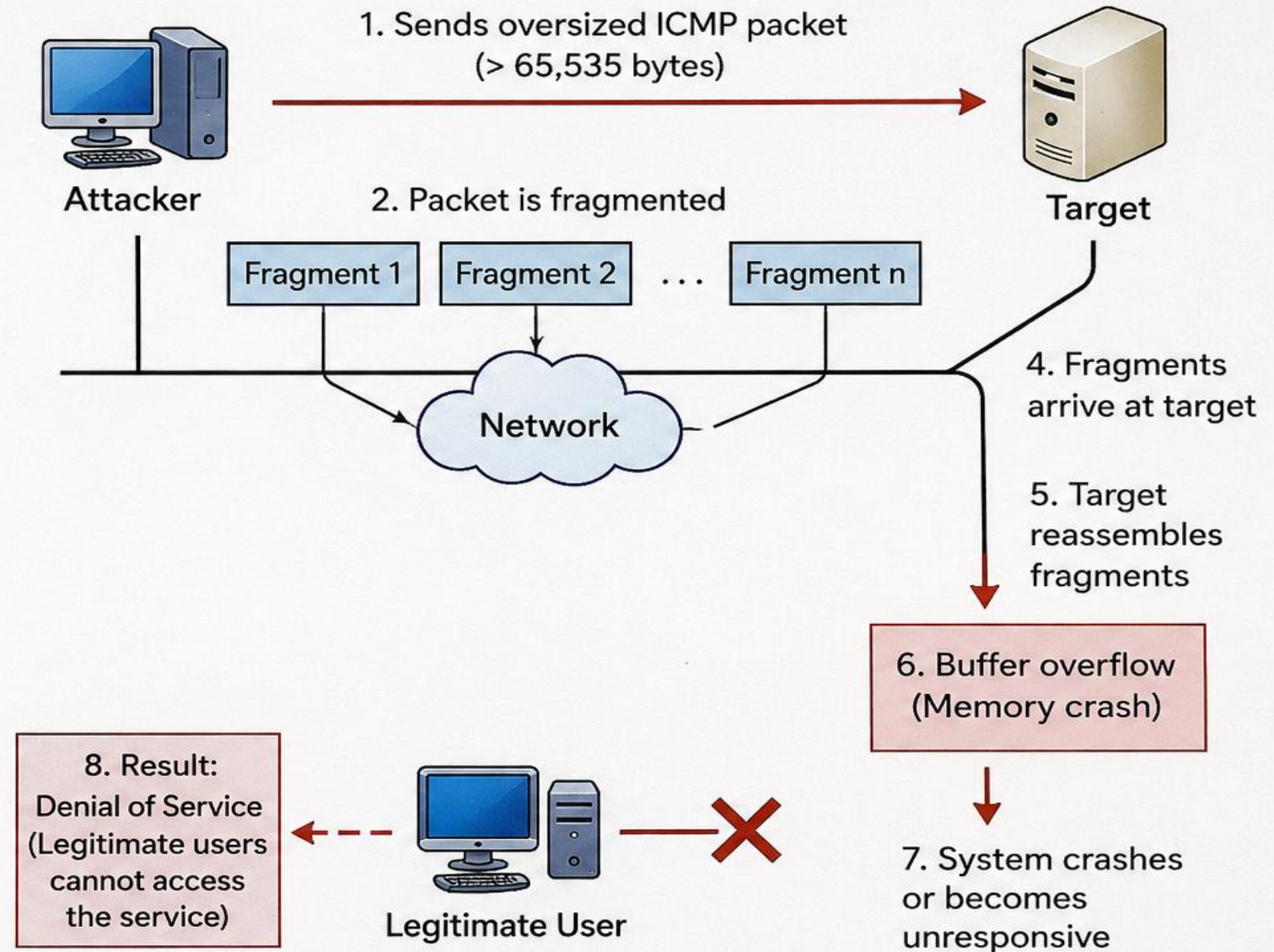
Limit the number of ICMP error responses sent per second to reduce the impact.

4. NETWORK MONITORING AND ANOMALY DETECTION

Detect unusual traffic patterns and take action quickly.

Ping of Death Attack – Step by Step

- 1 Attacker creates a very large ping (ICMP) packet.
- 2 The large packet is bigger than the allowed size (65,535 bytes).
- 3 The packet is split into many smaller IP fragments to travel across the network.
- 4 Fragments reach the target computer.
- 5 The target tries to reassemble all fragments into the original packet.
- 6 Because the packet is too large or malformed, it overflows the memory buffer.
- 7 The system crashes or becomes unresponsive.
- 8 Result: Legitimate users cannot access the service (Denial of Service).

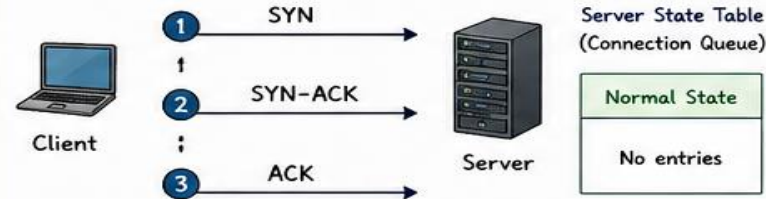


SYN FLOOD ATTACK USING IoT DEVICES (BOTNET)

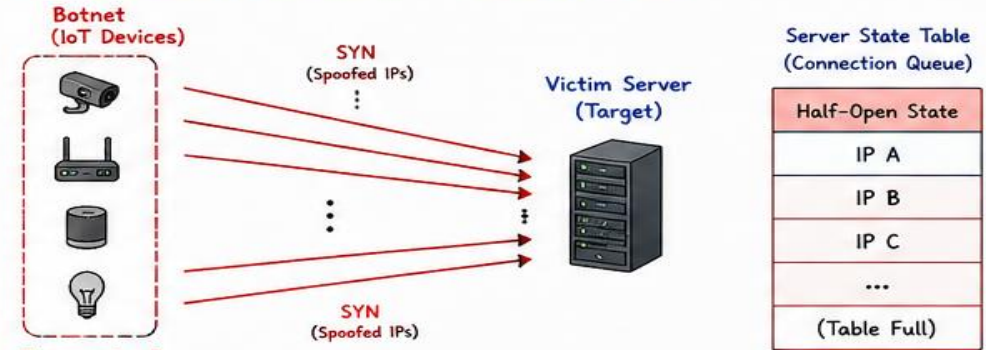
1. WHAT IS SYN FLOOD ATTACK?

SYN Flood is a type of Denial of Service (DoS) attack. The attacker sends a large number of TCP SYN requests (with fake source IPs) to a target server. The server allocates resources and waits for the final ACK. But the ACK never comes, so the server's connection table (half-open connections) gets full and real users cannot connect.

2. HOW TCP THREE-WAY HANDSHAKE WORKS



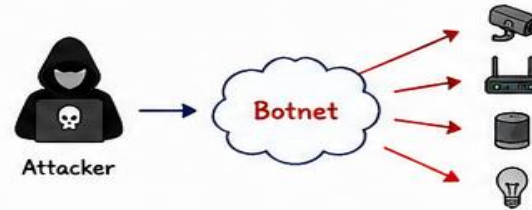
3. SYN FLOOD ATTACK – STEP BY STEP



1. Many IoT devices send TCP SYN packets with **spoofed** (fake) source IPs.
2. Server replies with SYN-ACK and allocates resources for each connection.
3. Because source IPs are fake, the final ACK never arrives.
4. Half-open connections fill the server's queue.
5. New legitimate users cannot connect. (Denial of Service)

4. HOW IoT DEVICES ARE USED?

- Attackers compromise a huge number of IoT devices (e.g., IP cameras, routers, smart TVs, sensors, etc.).
- These devices are controlled as a botnet.
- Each IoT device can send thousands of SYN packets per second.
- Together, they generate massive traffic that overwhelms the target server.



Why IoT? They are easy to compromise, always online, and exist in millions. Perfect for large scale attacks.

5. EXAMPLE SCENARIO

- A website is hosted on a server (203.0.113.10).
- An attacker creates a botnet of 50,000 IoT devices.
- Each device sends SYN packets with random spoofed IPs to port 80 of the server.
- The server's connection table size is 100,000.
- Within seconds, the table is full of half-open connections.
- Real users try to visit the website, but cannot connect.

Connection Table (Example)	
192.0.2.1	Half-Open
198.51.100.2	Half-Open
203.0.113.55	Half-Open
...	...
Table Full New connections dropped	

6. IMPACT

- ⌚ Server resources (CPU, Memory, Connection table) are exhausted.
- 👤 Legitimate users cannot access the service.
- ⬇️ Business loss, downtime, reputation damage.

7. COUNTERMEASURES

- ✓ Enable SYN Cookies (helps prevent half-open table exhaustion).
- ✓ Increase TCP backlog size (within system limits).
- ✓ Use Rate Limiting / Traffic Throttling on firewall or router.
- ✓ Deploy IDS/IPS to detect and block SYN flood traffic.
- ✓ Use Anti-DDoS solutions or cloud protection services.
- ✓ Filter spoofed IPs (BCP 38 – ingress/egress filtering).
- ✓ Keep systems, firmware, and network devices updated.



8. SUMMARY FLOW

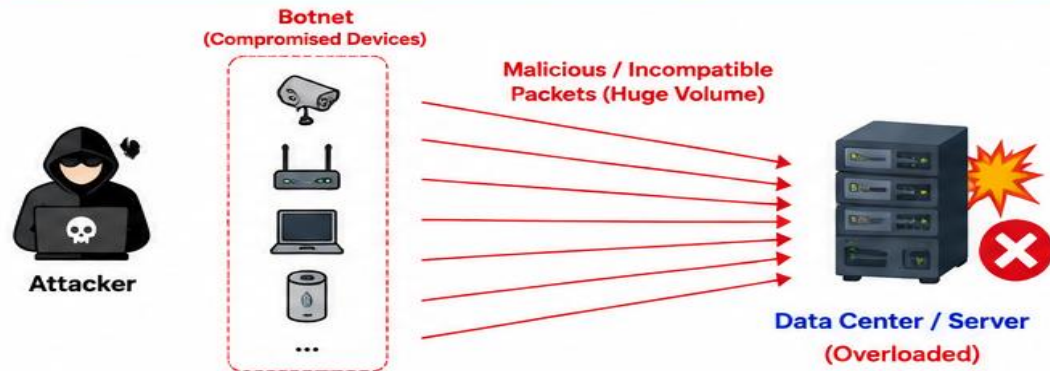


TYPES OF FLOODING

Flooding means sending a huge number of requests or packets to a target (such as a server or data center) so that it becomes overloaded and cannot respond to normal users.

1. FLOODING BY ATTACKERS (DDoS)

- Attackers send malicious or incompatible packets to the data center (DC).
- The goal is to overwhelm the server and make the service unavailable.
- This is a **Denial of Service (DDoS)** attack.



How it is handled?

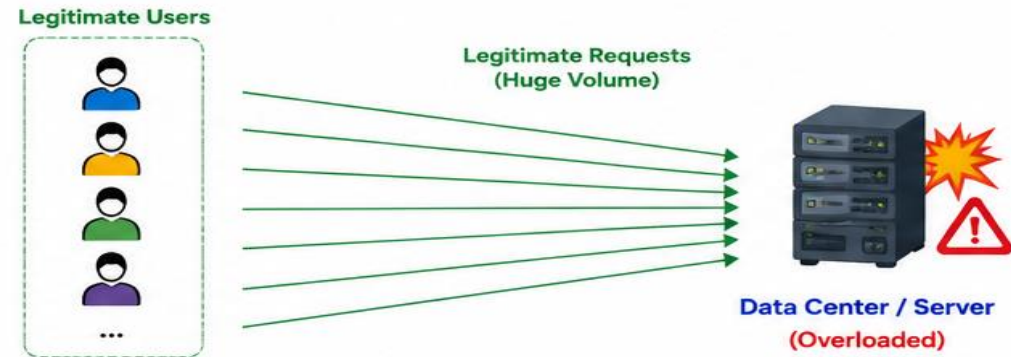
- ✓ This overload threat can be easily detected by tools like **Matchboard Profiler**.
- ✓ If the attacker's characteristics (IP address, pattern, traffic type) are found, that traffic can be filtered or blocked at the firewall.

Example

An attacker uses thousands of compromised IoT devices to send fake requests to a website, making it slow or completely unavailable for real users.

2. FLOODING BY LEGITIMATES (FLASH CROWD)

- A **flash crowd** is an overload condition caused by a large number of legitimate users requesting the data center resources at the same time.
- There is no malicious intent; it is just a sudden spike in traffic.



How it is handled?

- ✓ This can be solved by buffering an excess number of requests (using queues, load balancers, or auto-scaling) so that the overload condition remains only for a certain period of time.

Example

Many people try to buy tickets online for a popular concert at the same time. The website slows down due to heavy traffic, even though all users are real.

KEY DIFFERENCE

By Attackers (DDoS)

By Legitimates (Flash Crowd)

Who causes it?	Attackers with malicious intent	Real users with legitimate intent
Traffic type	Malicious / fake / incompatible packets	Legitimate requests
Goal	To make the service unavailable	To access the service (unintentional overload)
How to solve	Detect and block/filter the attacker's traffic	Buffer, queue, or scale resources to handle traffic

IN SIMPLE WORDS



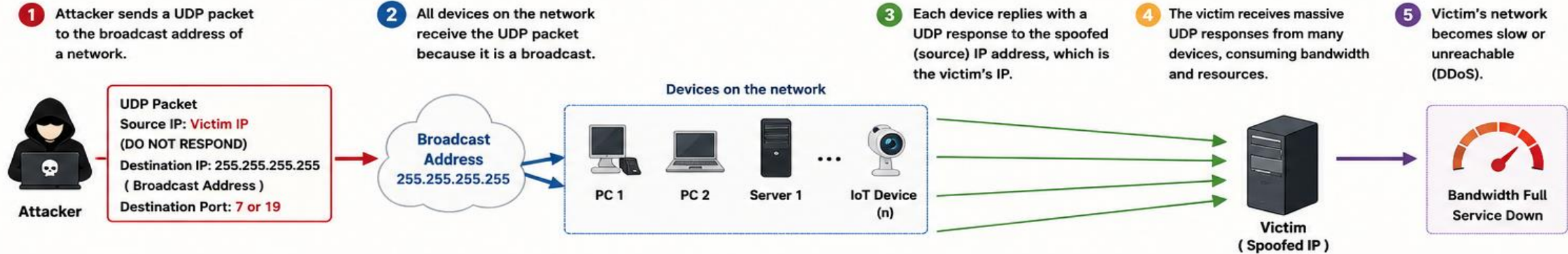
DDoS Flooding = Bad people flood the server with fake requests to crash it.



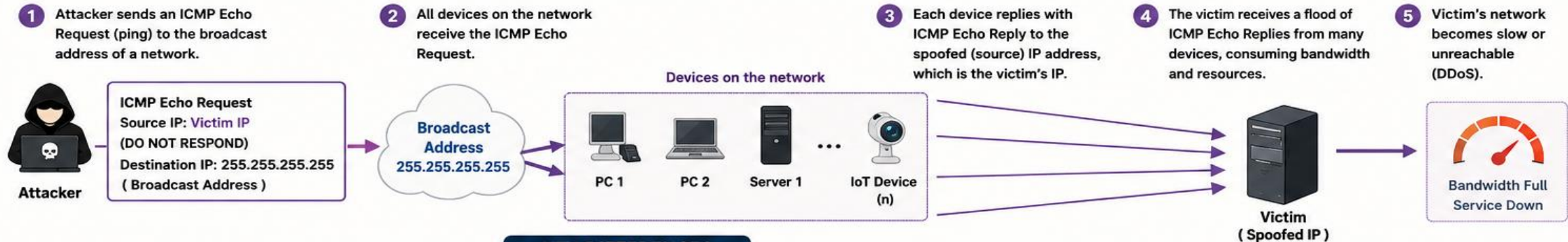
Flash Crowd = Good people flood the server by mistake (too many at once).

FRAGGLE ATTACK – HOW IT WORKS

A UDP based reflection/amplification DDoS attack using IP spoofing



ICMP ECHO REQUEST (SMURF) ATTACK – HOW IT WORKS (FOR COMPARISON)



KEY DIFFERENCES

	ICMP ECHO REQUEST (SMURF) ATTACK	FRAGGLE ATTACK
Protocol Used	ICMP (Echo Request)	UDP
Packet Type	ICMP Echo Request (Type 8)	UDP Packet
Destination Address	Broadcast Address (e.g., 255.255.255.255)	Broadcast Address (e.g., 255.255.255.255)
Destination Port	Not Applicable	UDP Port 7 (Echo) or 19 (Chargen)
Reply Type	ICMP Echo Reply (Type 0)	UDP Reply
Purpose	Abuses ICMP to flood the victim	Abuses UDP services (Echo/Chargen) to flood the victim
Example Tools	smurf.c, hping3 (--icmp)	fraggle.c, hping3 (--udp -p 7/19)

IN SIMPLE WORDS

ICMP Echo Request (Smurf):
Attacker sends a "ping" to everyone (broadcast) with victim's IP as source. Everyone replies with "pong" (ICMP reply) to the victim.

Fraggle Attack:
Attacker sends a UDP packet to everyone (broadcast) with victim's IP as source. Everyone replies with UDP response to the victim.



Both attacks use IP Spoofing + Broadcast + Reflection to flood the victim and cause Denial of Service (DDoS).

Modification of sensitive data

- During transit from sensors, the data can be captured, modified, and forwarded to the intended node.
- Complete data need not be modified; part of the message is sufficient to fulfil the intention.
- Modification takes place in three ways:
 - **Content modification**, in which part of the information has been altered
 - **Sequence modification**, in which the data delivery has been disordered, making the message meaningless
 - **Time modification**, which could result in replay attack.
- For example, if an ECG report has been altered during a telemedicine diagnosis, the patient may lose his or her life.
- Similarly, in road traffic, if the congestion or accident has not been notified to following traffic, it could result in another disaster.

IoT ATTACK: MODIFICATION OF SENSITIVE DATA

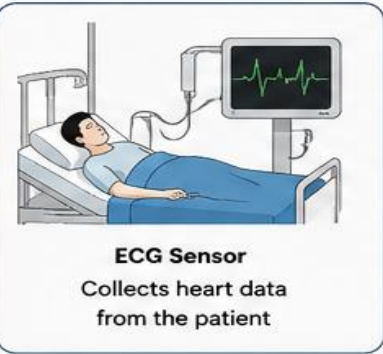
An attacker alters data in transit between IoT sensors and the intended server

SCENARIO: Telemedicine – ECG Monitoring System

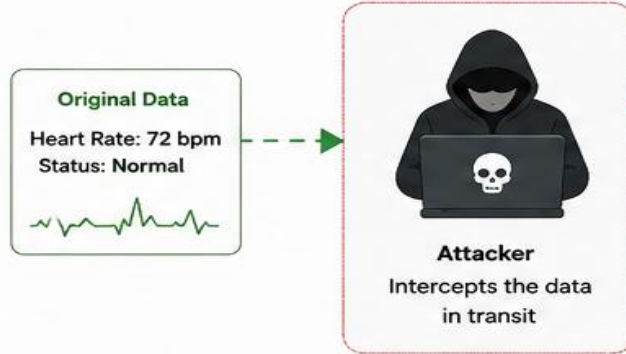
An ECG sensor on a patient sends real-time heart data to a hospital server.

An attacker intercepts the data, modifies it, and forwards it to the server.

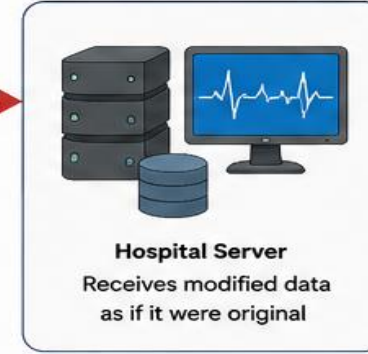
1. DATA ORIGIN (IoT SENSOR)



2. ATTACKER POSITION



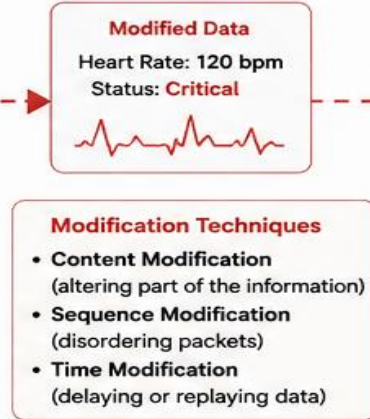
3. INTENDED NODE (SERVER)



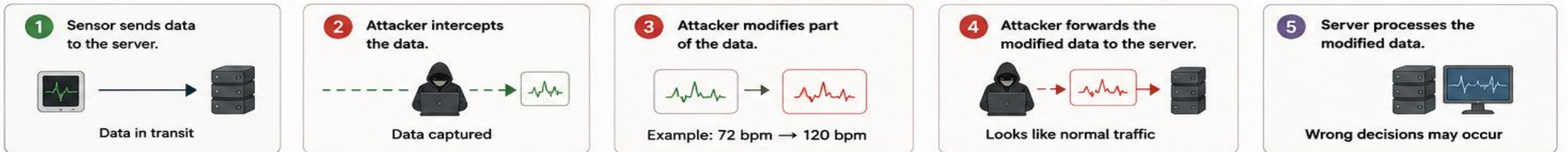
4. CONSEQUENCE



The server and application trust the data because it appears to come from a legitimate sensor.



HOW THE ATTACK WORKS (STEP-BY-STEP)



THREE WAYS DATA CAN BE MODIFIED

Type	Description	Example in IoT
1 Content Modification	Part of the information is altered (values, commands, readings).	Changing "Normal" to "Critical" in a patient's ECG status.
2 Sequence Modification	The order of data packets is changed, deleted, or inserted.	Reordering traffic updates so that an accident alert arrives late.
3 Time Modification	Delaying, replaying, or accelerating data to create a false timeline.	Replaying old temperature data to hide a real-time overheating.

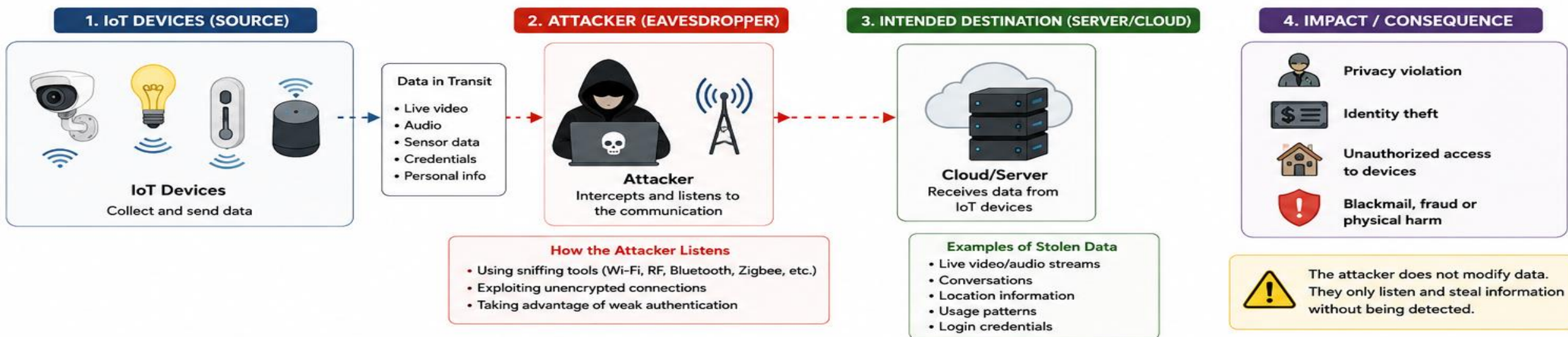
PREVENTION MEASURES

- Use end-to-end encryption (TLS/DTLS) for sensor data.
- Implement message authentication (HMAC, digital signatures).
- Use sequence numbers and timestamps to detect tampering or replay.
- Deploy Intrusion Detection Systems (IDS) for IoT networks.
- Regularly update firmware and close communication loopholes.



IoT ATTACK: EAVESDROPPING ATTACK

An attacker secretly listens to communications between IoT devices and the server to steal data



HOW EAVESDROPPING ATTACK WORKS (STEP-BY-STEP)



COMMON VECTORS IN IoT

- Unsecured Wi-Fi networks (open or weak encryption)
- Bluetooth Low Energy (BLE) sniffing
- RF protocols (Zigbee, Z-Wave, LoRa) without encryption
- HTTP / MQTT / CoAP communication without TLS/DTLS
- Weak authentication between device and server

EXAMPLE SCENARIO: SMART HOME

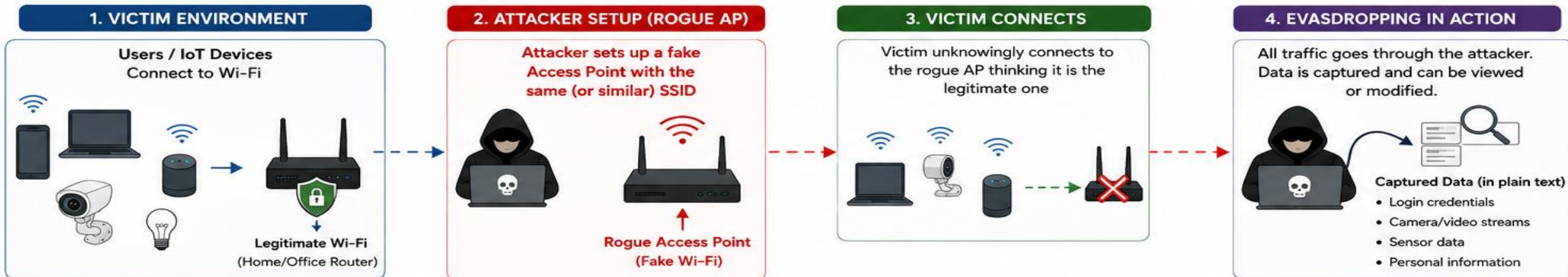


PREVENTION AND DEFENSE

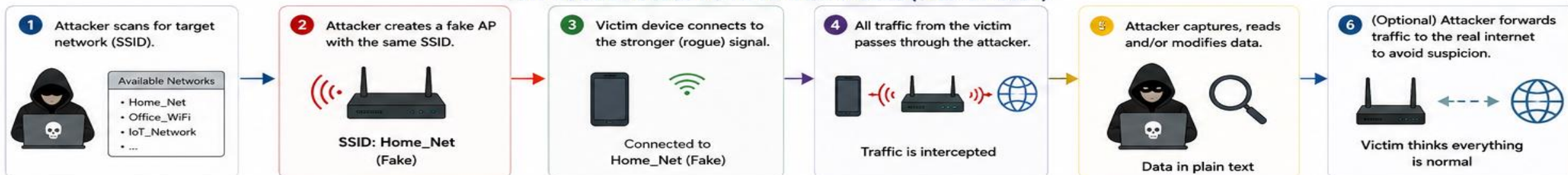
- Use end-to-end encryption (TLS/DTLS) for all communications.
- Use strong authentication and unique credentials.
- Disable unnecessary services and open ports.
- Use secure protocols (HTTPS, MQTT over TLS, CoAP over DTLS).
- Regularly update firmware and patch vulnerabilities.
- Monitor network traffic and use IDS/IPS for IoT.

IoT ATTACK: ROGUE ACCESS POINT (EVASDROPPING)

An attacker sets up a fake Wi-Fi access point to lure IoT devices/users and eavesdrop on their data



HOW ROGUE ACCESS POINT ATTACK WORKS (STEP-BY-STEP)



WHY IT WORKS

- ✓ Many devices auto-connect to the strongest known SSID.
- ✓ Users often don't check for HTTPS (encrypted) connections.
- ✓ IoT devices may not validate certificates or use weak security.
- ✓ Unencrypted protocols (HTTP, MQTT, RTSP, Telnet, etc.) send data in plain text.

EXAMPLE SCENARIO: SMART HOME



SIGNS OF ROGUE AP

- ! Unknown AP with same SSID.
- ! Multiple APs with the same name.
- ! Devices frequently disconnect/reconnect.
- ! Unusual pop-ups / certificate warnings.
- ! Slow internet or redirection to login pages.

PREVENTION & DEFENSE

- 🛡️ Use WPA3/WPA2-Enterprise with strong authentication.
- 🛡️ Enable HTTPS/TLS for all services.
- 🛡️ Use VPN for remote access.
- 🛡️ Disable auto-connect and verify the network before connecting.
- 🛡️ Monitor for rogue APs (Wireless IDS/WIPS).
- 🛡️ Use certificate pinning on IoT/mobile apps.
- 🛡️ Segment IoT devices on a separate network (VLAN).



A Rogue Access Point attack is a powerful method for eavesdropping because it is easy to launch and hard for users/devices to detect.

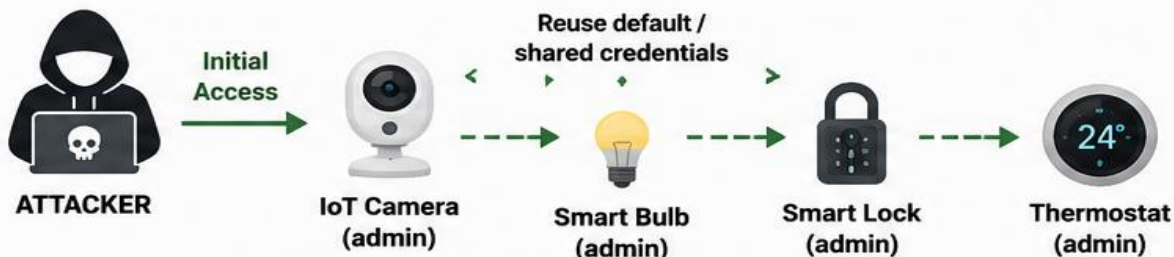
Three Common types of Attack in IoT

- **Privilege Escalation Attack,** A privilege escalation attack involves obtaining unauthorized access of privileges or elevated rights by a malicious insider or an external attacker. In privilege escalation attacks, threat actors exploit privilege escalation vulnerabilities such as unpatched bugs in the system, misconfiguration, or inadequate access controls.

PRIVILEGE ESCALATION IN IoT

1) HORIZONTAL ESCALATION

Moving to other devices/accounts with the same level of privilege

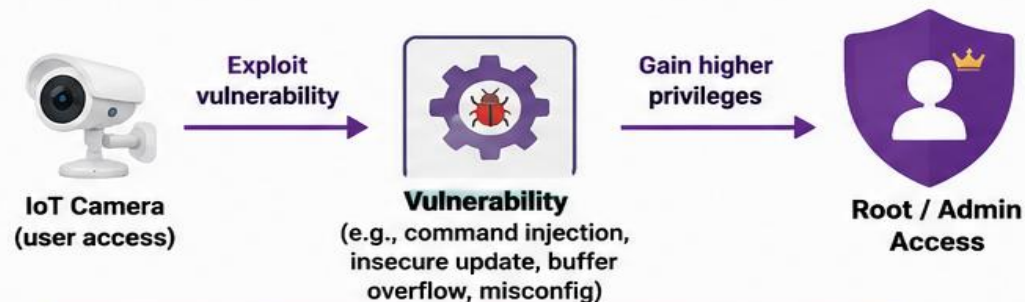


HOW IT HAPPENS

- Default or weak credentials used across multiple devices
- Same admin panel / API on many devices
- Information leakage (e.g., passwords, tokens, WIFI creds)
- Network access allows the attacker to reach other devices

2) VERTICAL ESCALATION

Gaining higher privileges on the same device/system



HOW IT HAPPENS

- Exploiting software/firmware vulnerabilities
- Insecure file permissions or misconfigurations
- Running services as root
- Insecure update mechanisms or backdoors

WHAT IS THE TARGET / GOAL?

After gaining (horizontal or vertical) access, attackers can perform different objectives:



DENIAL OF SERVICE

Crash the device or network making services unavailable



SNIFFING / EAVESDROPPING

Capture network traffic, steal sensitive data, monitor user activity



DATA THEFT

Steal credentials, personal information, images, or configuration data



MALWARE INSTALLATION

Install backdoors, ransomware, or bots to maintain persistent access



BOTNET / DDOS

Use compromised IoT devices to launch DDoS attacks on other systems



EVASION / COVERING TRACES

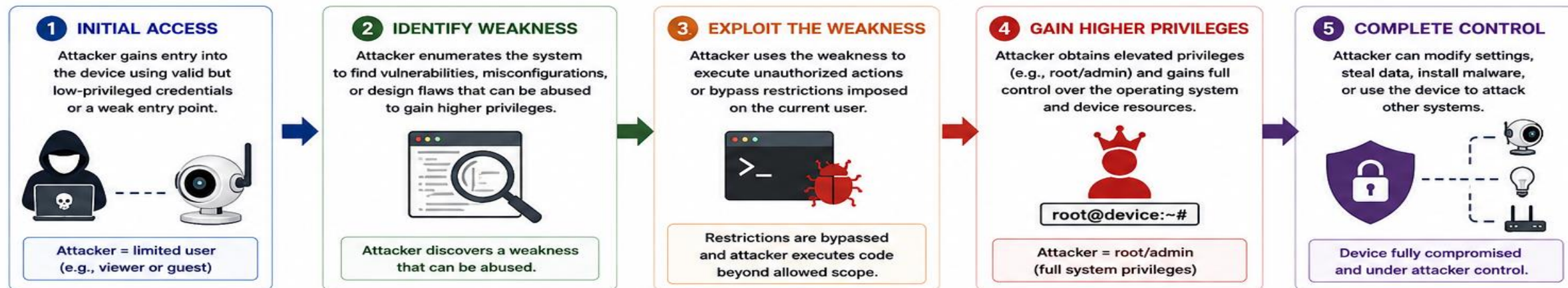
Clear logs, disable security features, hide processes to avoid detection



IMPACT: Loss of privacy, financial loss, service disruption, safety risks (especially in critical IoT), and the compromised device can be used to attack others.

VERTICAL ESCALATION IN IoT – DETAILED EXPLANATION

An attacker starts with limited access on an IoT device and exploits weaknesses to gain higher privileges (root/admin).



HOW EACH TECHNIQUE LEADS TO VERTICAL ESCALATION (IN DETAIL)

1. EXPLOITING SOFTWARE / FIRMWARE VULNERABILITIES

The device software contains bugs that allow execution of unauthorized commands or code.

How it works:

- Vulnerabilities like command injection, buffer overflow, path traversal, authentication bypass can be exploited.
- These bugs allow the attacker to escape the restrictions of the current user.
- Attacker can execute system-level commands or spawn a privileged shell.

Example: The camera's web interface has a command injection flaw. Attacker injects OS commands and gets a shell with higher privileges.

2. INSECURE FILE PERMISSIONS OR MISCONFIGURATIONS

Important files, directories, or configurations are improperly protected and can be modified by low-privileged users.

How it works:

- Device allows write access to critical files or directories.
- Attacker modifies system configuration or startup scripts.
- Modified files give the attacker more rights the next time a service or system starts.

Example: A configuration file that controls user roles is writable. Attacker changes it to add himself as admin, then logs in with full rights.

3. RUNNING SERVICES AS ROOT

Some services or applications run with root privileges instead of an unprivileged user.

How it works:

- Attacker exploits a vulnerability in a service (e.g., web server, telnet, SSH, Upnp).
- Because the service runs as root, the attacker's code also runs as root.
- This immediately grants full system control.

Example: The device's web server runs as root. Attacker exploits a small bug in the web application and gets a root shell.

4. INSECURE UPDATE MECHANISM

Firmware update process lacks verification of authenticity and integrity.

How it works:

- Device accepts firmware images without verifying digital signatures.
- Attacker uploads a modified firmware containing backdoor or root access.
- When the device boots, malicious firmware executes with full privileges.

Example: Attacker uploads a modified firmware via the update feature. The firmware contains a backdoor that provides root access.

WHAT IS THE TARGET / GOAL AFTER GETTING ROOT?



DENIAL OF SERVICE (DoS)

Crash the device or consume resources to make the service unavailable.



SNIFFING / EAVESDROPPING

Capture network traffic, monitor communications, and steal sensitive data.



DATA THEFT

Steal credentials, images, videos, configuration files, or sensor data.



MALWARE / BACKDOOR

Install persistent backdoors, ransomware, or spyware for long-term access.



BOTNET / DDoS

Use the device as part of a botnet to launch DDoS attacks on other systems.



EVASION / COVERING TRACKS

Clear logs, disable security features, and hide malicious activity to avoid detection.

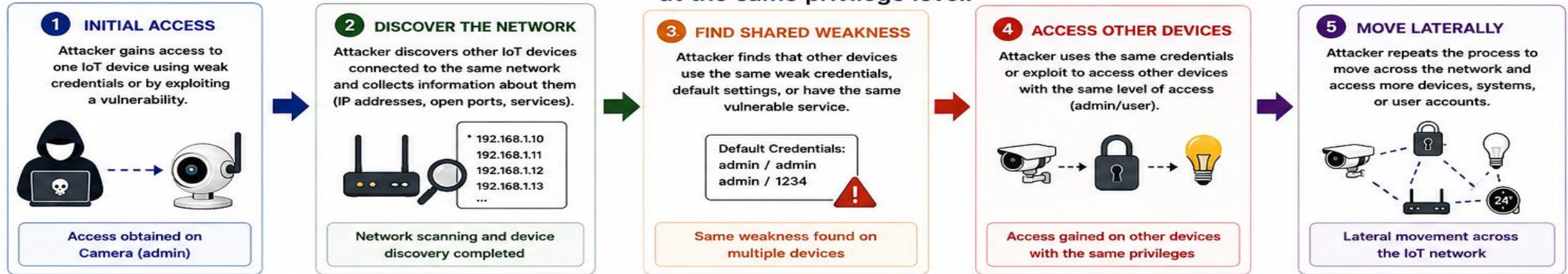


IMPACT:

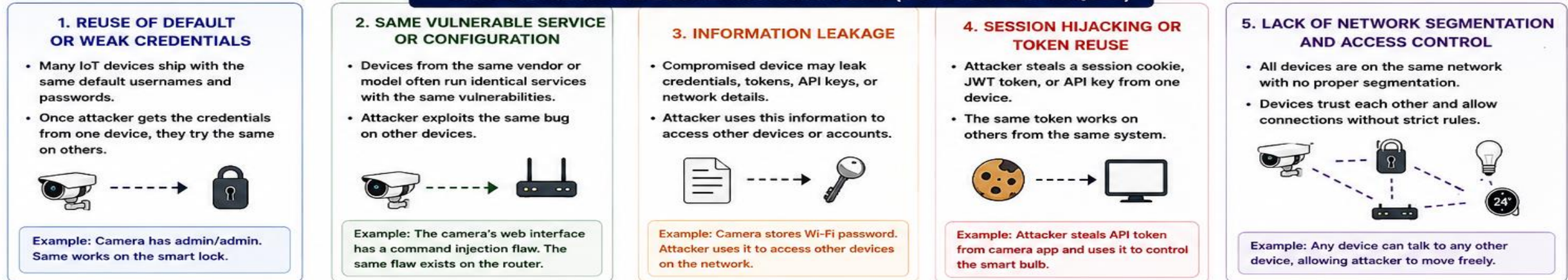
Loss of privacy • Financial loss • Service disruption • Physical safety risks (in critical IoT systems) • The compromised device can be used as a stepping stone to attack other devices and the entire network.

HORIZONTAL ESCALATION IN IoT – DETAILED EXPLANATION

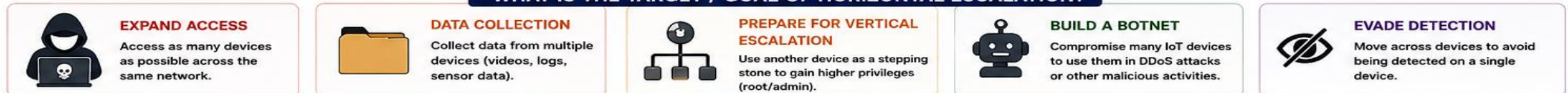
An attacker uses the same level of access on one device to move laterally and access other devices or accounts at the same privilege level.



HOW HORIZONTAL ESCALATION HAPPENS (COMMON TECHNIQUES)



WHAT IS THE TARGET / GOAL OF HORIZONTAL ESCALATION?

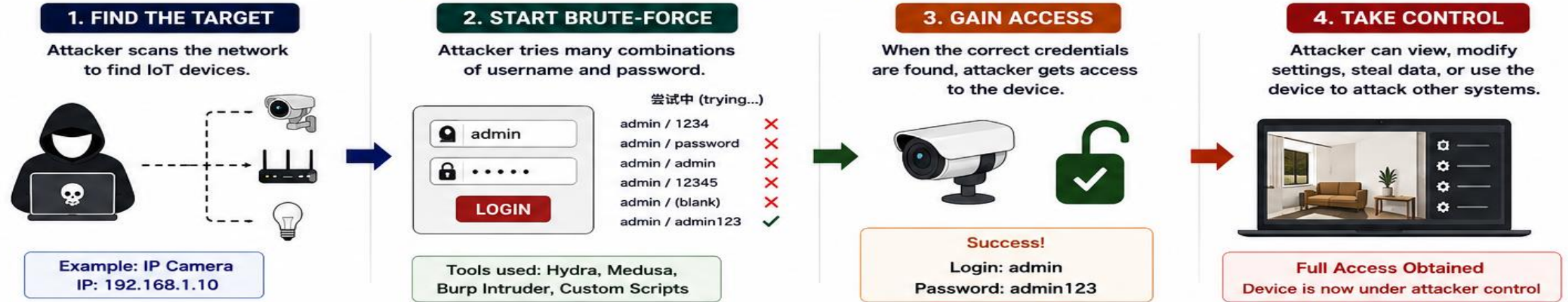


IMPACT:

Wider compromise of the IoT network • Loss of privacy and sensitive data • Service disruption
Used as a launchpad for larger attacks • Increased damage and recovery cost

BRUTE-FORCE ATTACK IN IoT – HOW IT WORKS

Attackers guess login credentials repeatedly until they get access to the IoT device.



WHY BRUTE-FORCE ATTACKS WORK ON IoT DEVICES?



COMMON TARGETS IN IoT



WHAT CAN ATTACKERS DO AFTER GETTING ACCESS?



COUNTERMEASURES

- ✓ Change default credentials immediately
- ✓ Use strong, unique passwords
- ✓ Enable account lockout after failed attempts
- ✓ Use HTTPS, SSH instead of Telnet/HTTP
- ✓ Enable 2FA / MFA for device access
- ✓ Monitor and log login attempts
- ✓ Keep firmware and software up to date
- ✓ Limit device exposure to the internet



IMPACT: Loss of privacy • Data theft • Device manipulation • Service disruption • Botnet attacks • Safety risks (especially in critical IoT systems)

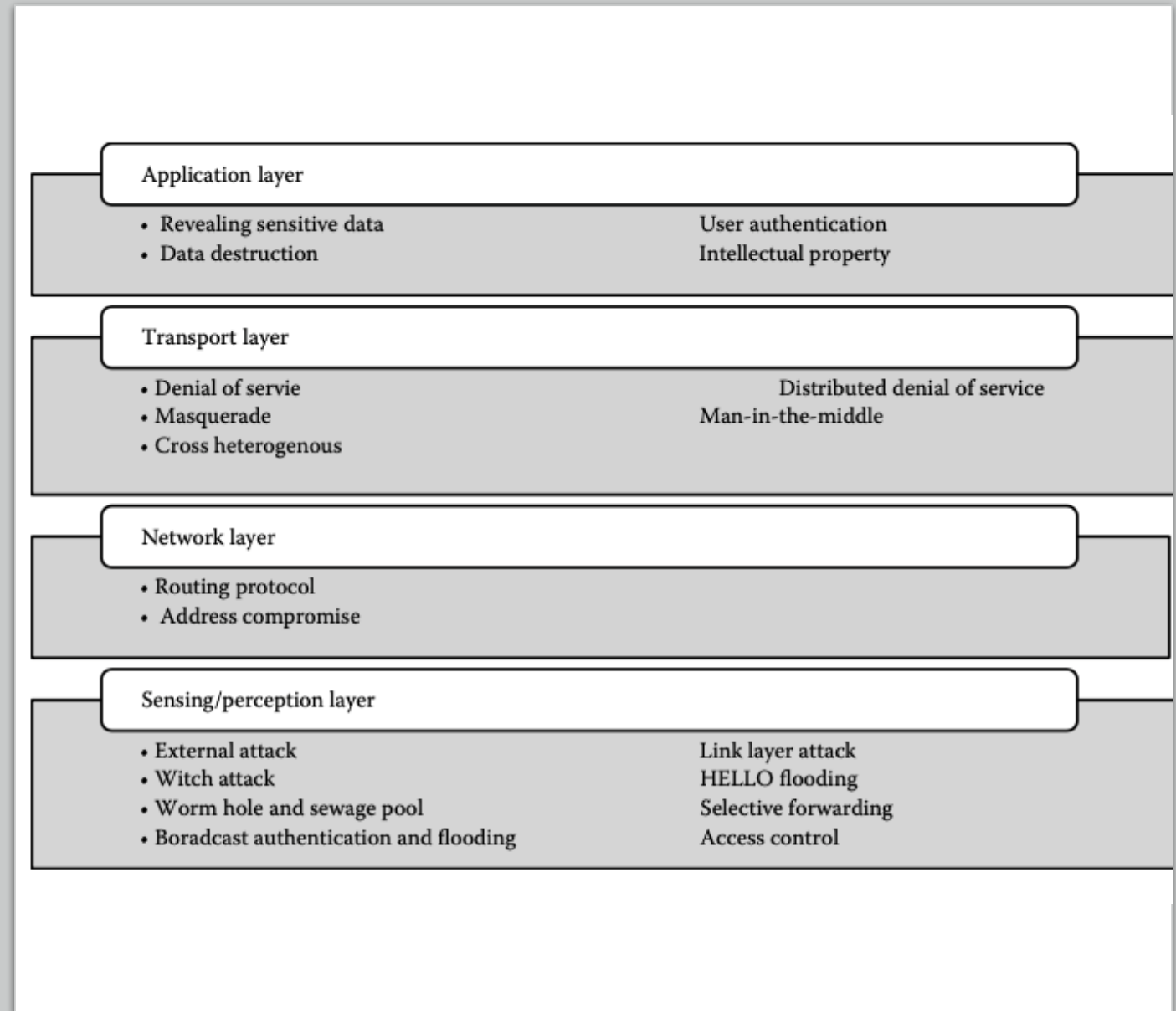
Three Common types of Attack in IoT

- **Brute-Force Attack**, Most IoT device users keep the default or easy-to-remember passwords, allowing brute-force attackers to access the targeted IoT connections quickly. In brute-force attacks, threat actors guess passwords using dictionaries or common word combinations to penetrate IoT networks. Enabling robust authentication procedures like two-factor authentication (2FA), multi-factor authentication (MFA), and zero-trust models can mitigate brute-force attacks.

Attacks as per architecture

Attacks as per architecture

- The IoT has not yet been confined to a particular architecture.
- Different vendors and applications adopt their own layers.
- In general, the IoT is assumed to have four layers: the lowest-level perception layer or sensing layer, the network layer, the transmission layer, and the application layer.

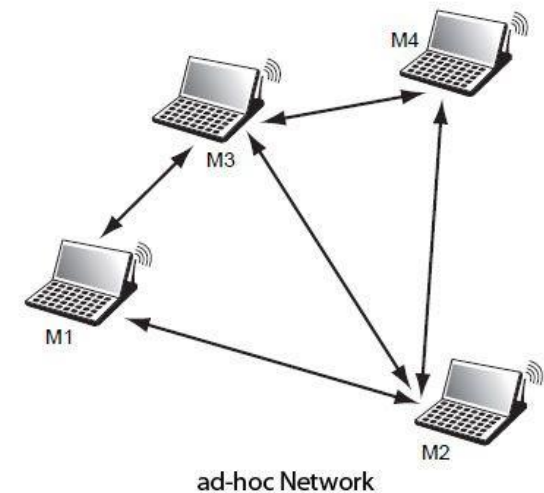


External attack

- In order to make full use of the benefits of the IoT, security issues need to be addressed first.
- Trustworthiness of the cloud service provider is the key concern.
- Organizations deliberately offload both sensitive and insensitive data to obtain the services.
- But they are unaware of the location where their data will be processed or stored.
- It is possible that the provider may share this information with others, or the provider itself may use it for malicious actions.

Ad-Hoc Wireless Network Review

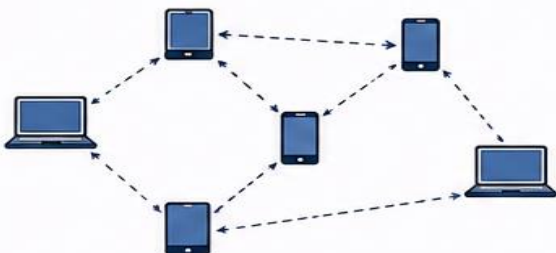
- In ad-hoc networks, each node can communicate with other nodes, so no access point that provides access control is required.
- In ad-hoc networks the nodes in the network take care of **routing**.
- Routing is to find the best possible path between the source and destination nodes to transfer data.
- All the individual nodes in an ad-hoc network maintain a routing table, which contains the information about the other nodes.
- As the nature of the ad-hoc network is dynamic, this results in ever-changing router tables.
- One important thing to note is that an ad-hoc network is asymmetric by nature, meaning the path of data upload and download between two nodes in the network may be different.



AD-HOC WIRELESS NETWORK – OVERVIEW

1. WHAT IS AN AD-HOC NETWORK?

An ad-hoc wireless network is a collection of wireless nodes that **communicate directly** with each other **without relying on any** centralized **infrastructure** or access point.



Every node acts as both an end system and a router.

2. WHY AD-HOC NETWORKS?

Used in situations where infrastructure is not available, not practical, or too costly.



Disaster Recovery

Communication when infrastructure is damaged.



Military Operations

Secure communication in battlefield environments.



Temporary Events

Conferences, exhibitions, or meetings without fixed network.



Remote Areas

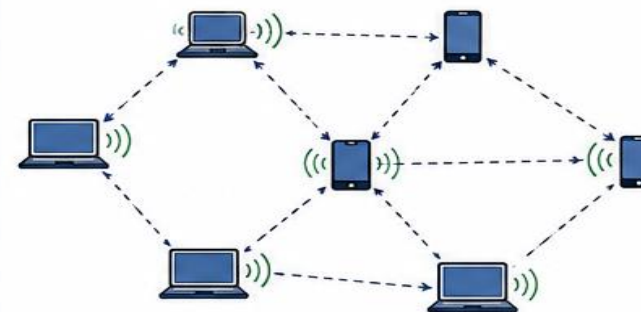
Providing network access in areas where infrastructure is unavailable.



IoT & Sensor Networks

Connecting devices in dynamic and infrastructure-less environments.

3. HOW AD-HOC NETWORKS WORK



Example Path: A → B → D → E → F

The path may change whenever the network topology changes.

- 1 Node A wants to send data to Node F. Node...
- 2 Node A finds a neighbor (e.g., B) and forwards the data.
- 3 Each intermediate node forwards the data closer to the destination.
- 4 Data reaches Node F through multiple hops.

--- Wireless Link

((...)) Wireless Communication Range

4. MAIN CHARACTERISTICS



Decentralized

No central controller or access point.



Self-Configuring

Nodes automatically discover each other and form a network.



Multi-Hop Communication

Data is forwarded through intermediate nodes to reach the destination.



Dynamic Topology

Nodes can join, leave, or move at any time.



Limited Resources

Nodes usually have limited battery power, processing, and storage.



Asymmetric Links

The link quality or path from A to B may differ from B to A.

5. MAIN SOLUTIONS / TECHNOLOGIES



Routing Protocols

Protocols like AODV, DSR, OLSR, ZRP help nodes find and maintain routes.



Topology Management

Nodes exchange control messages to maintain up-to-date network topology.



Medium Access Control (MAC)

MAC protocols (e.g., IEEE 802.11, CSMA/CA) coordinate wireless channel access.



Power Management

Techniques to save energy and extend network lifetime.



Security Mechanisms

Encryption, authentication, and trust management to protect data and nodes.



Mobility Management

Handling node movement and maintaining stable connections.

6. ADVANTAGES

- ✓ No infrastructure cost.
- ✓ Easy and quick to deploy.
- ✓ Highly scalable.
- ✓ Robust in disaster scenarios.
- ✓ Flexible and self-organizing.

7. CHALLENGES

- ⚠ Dynamic topology causes route breaks.
- ⚠ Limited bandwidth and higher delay.
- ⚠ Security is more complex.
- ⚠ Energy constraints of nodes.
- ⚠ Harder to manage and monitor.

8. TYPICAL APPLICATION EXAMPLES



Disaster Relief



Military Networks



VANET (vehicular)



IoT / Sensor Networks



Remote Conferences

SUMMARY

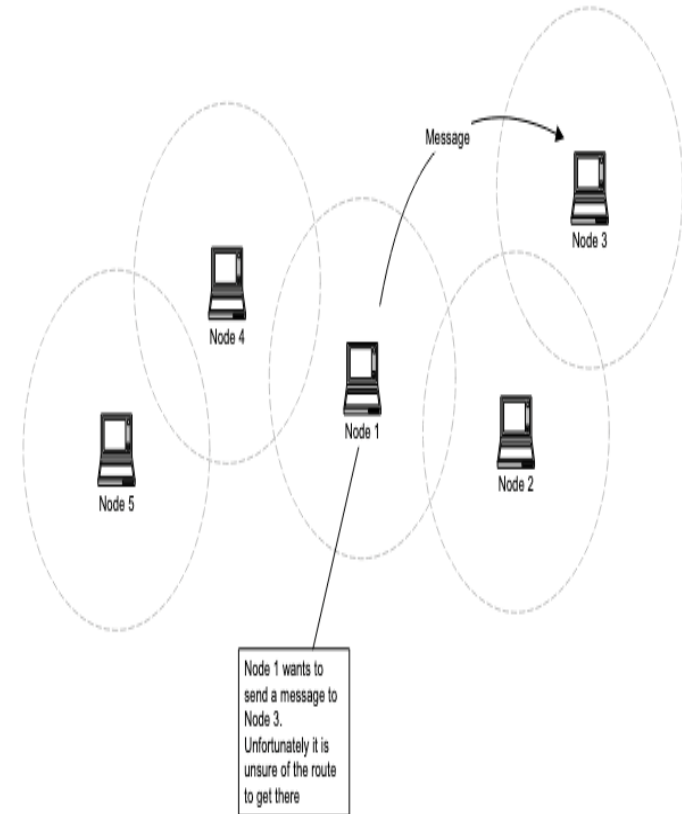
An ad-hoc wireless network is a self-organizing, infrastructure-less network where nodes communicate directly and cooperatively. It is highly useful in dynamic, temporary, and critical environments, but it faces challenges in routing, security, and resource management.

Why Routing is Challenging in Ad-Hoc Networks?

- Nodes move frequently.
- Connections may break.
- New nodes join the network.
- Existing nodes leave the network.
- Multiple routes may exist.

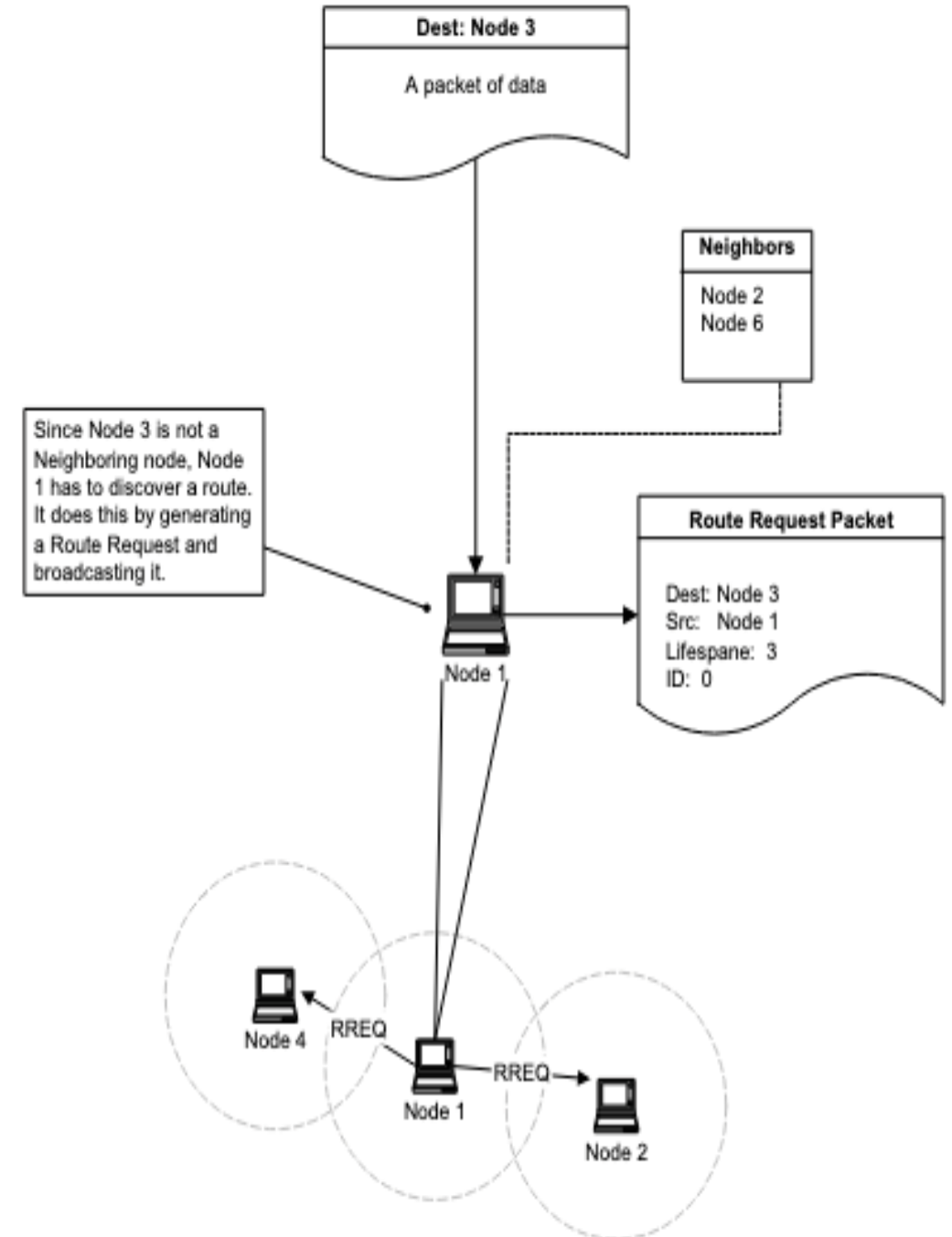
AODV(Ad-hoc on-demand distance vector)Example

- AODV is a method of routing messages between mobile computers. It allows these mobile computers, or nodes, to pass messages through their neighbours to nodes with which they cannot directly communicate.
- AODV does this by discovering the routes along which messages can be passed.
- AODV makes sure these routes do not contain loops and tries to find the shortest route possible.
- AODV is also able to handle changes in routes and can create new routes if there is an error.
- The diagram to the left shows a set up of four nodes on a wireless network.
- The circles illustrate the range of communication for each node.
- Because of the limited range, each node can only communicate with the nodes next to it.



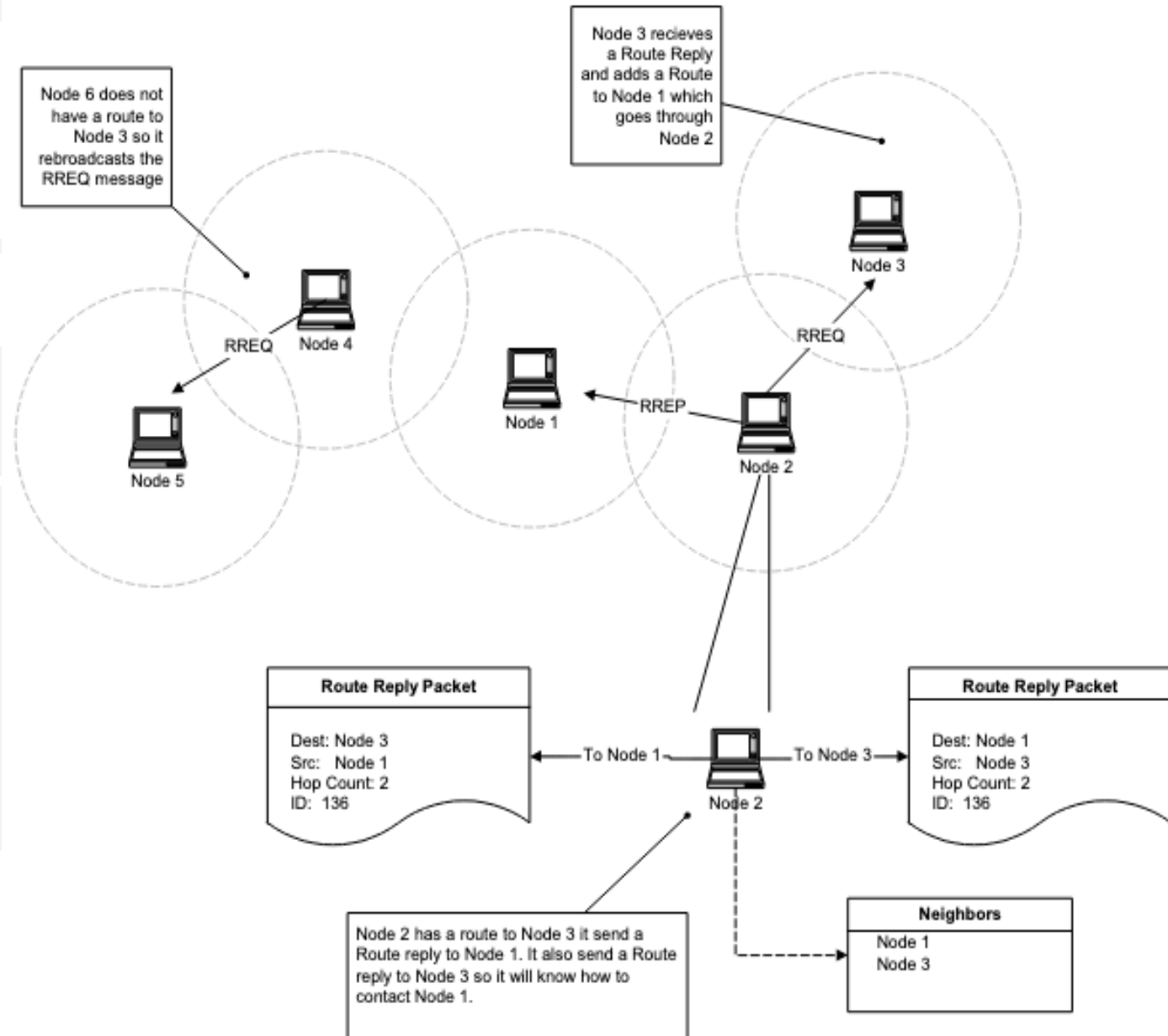
AODV Example..

- Nodes you can communicate with directly are considered to be Neighbours.
- A node keeps track of its Neighbours by listening for a HELLO message that each node broadcast at set intervals.
- When one node needs to send a message to another node that is not its Neighbour it broadcasts a Route Request (RREQ) message.
- The RREQ message contains several key bits of information: the source, the destination, the lifespan of the message and a Sequence Number which serves as a unique ID.
- In the example, Node 1 wishes to send a message to Node 3.
- Node 1's Neighbours' are Nodes 2 + 4.
- Since Node 1 can not directly communicate with Node 3, Node 1 sends out a RREQ.
- The RREQ is heard by Node 4 and Node 2.



AODV Example..

- When Node 1's Neighbours receive the RREQ message they have two choices; if they know a route to the destination or if they are the destination they can send a Route Reply (RREP) message back to Node 1, otherwise they will rebroadcast the RREQ to their set of Neighbours.
- The message keeps getting rebroadcast until its lifespan is up.
- If Node 1 does not receive a reply in a set amount of time, it will rebroadcast the request except this time the RREQ message will have a longer lifespan and a new ID number.
- All of the Nodes use the Sequence Number in the RREQ to insure that they do not rebroadcast a RREQ
- In the example, Node 2 has a route to Node 3 and replies to the RREQ by sending out a RREP.
- Node 4 on the other hand does not have a route to Node 3 so it rebroadcasts the RREQ.

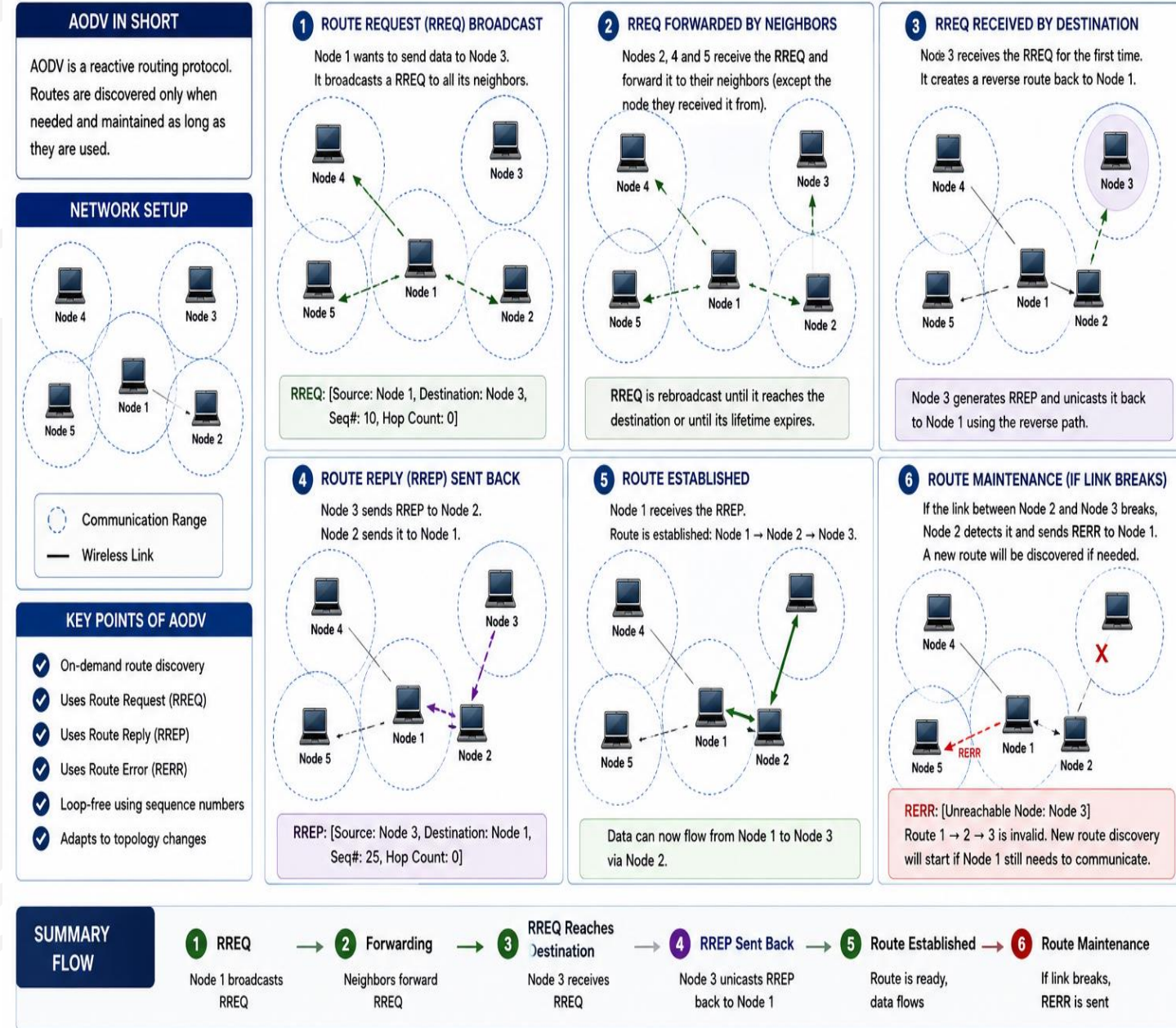


AODV (AD-HOC ON-DEMAND DISTANCE VECTOR) – EXAMPLE

AODV Example..

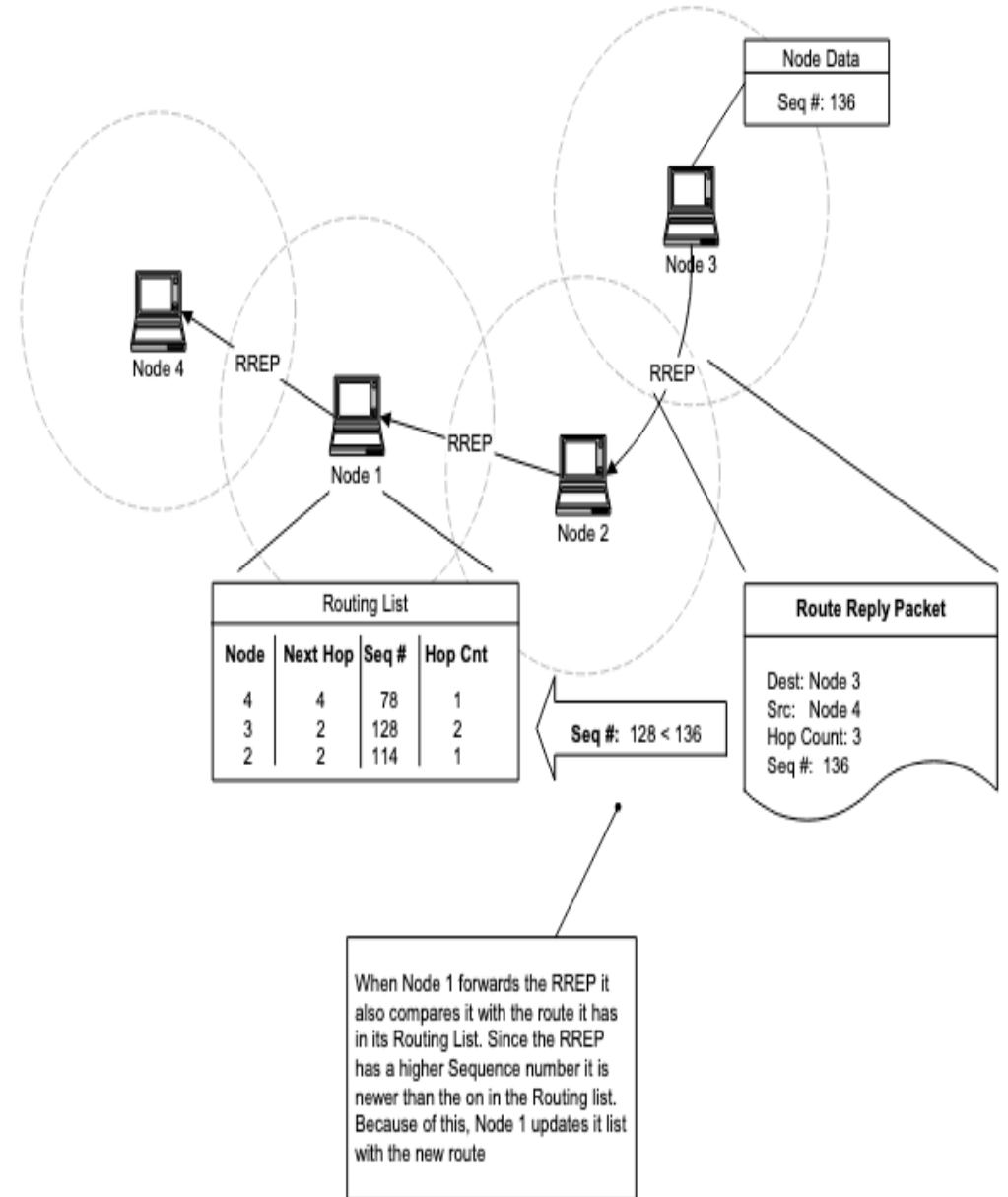
- When Node 1's Neighbours receive the RREQ message they have two choices; if they know a route to the destination or if they are the destination they can send a Route Reply (RREP) message back to Node 1, otherwise they will rebroadcast the RREQ to their set of Neighbours.
- The message keeps getting rebroadcast until its lifespan is up.
- If Node 1 does not receive a reply in a set amount of time, it will rebroadcast the request except this time the RREQ message will have a longer lifespan and a new ID number.
- All of the Nodes use the Sequence Number in the RREQ to insure that they do not rebroadcast a RREQ
- In the example, Node 2 has a route to Node 3 and replies to the RREQ by sending out a RREP.
- Node 4 on the other hand does not have a route to Node 3 so it rebroadcasts the RREQ.

Scenario: Node 1 wants to send data to Node 3. They cannot communicate directly.



AODV Example..

- Sequence numbers serve as time stamps, they allow nodes to compare how “fresh” their information on other nodes is.
- Every time a node sends out any type of message it increase its own Sequence number.
- Each node records the Sequence number of all the other nodes it talks to.
- A higher Sequence numbers signifies a fresher route.
- This it is possible for other nodes to figure out which one has more accurate information.
- In the example, Node 1 is forwarding a RREP to Node 4.
- It notices that the route in the RREP has a better Sequence number than the route in it's Routing List.
- Node 1 then replaces the route it currently has with the route in the Route Reply

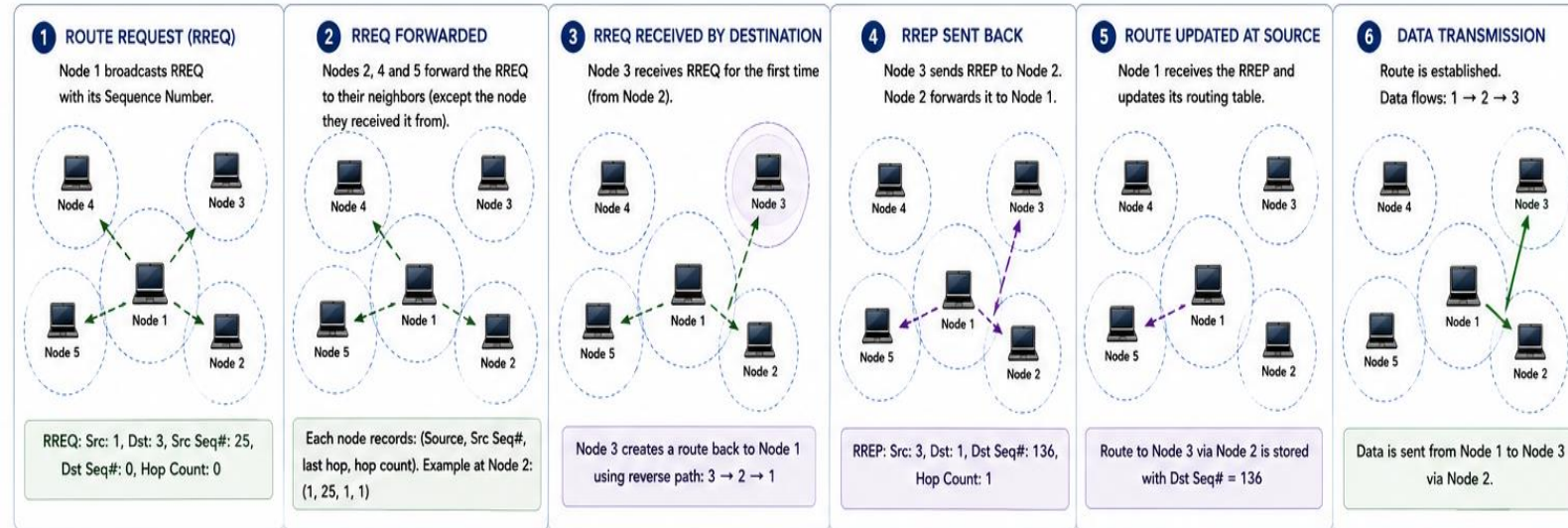


AODV Example..

- Sequence numbers serve as time stamps, they allow nodes to compare how “fresh” their information on other nodes is.
- Every time a node sends out any type of message it increase its own Sequence number.
- Each node records the Sequence number o all the other nodes it talks to.
- A higher Sequence numbers signifies a fresher route.
- This it is possible for other nodes to figure out which one has more accurate information.
- In the example, Node 1 is forwarding a RREP to Node 4.
- It notices that the route in the RREP has a better Sequence number than the route in it's Routing List.
- Node 1 then replaces the route it currently has with the route in the Route Reply

AODV - SEQUENCE NUMBER EXAMPLE (ROUTE FRESHNESS)

Scenario: Node 1 wants to send data to Node 3.



ROUTING TABLE AT EACH NODE (EXAMPLE ENTRIES)

Node	Destination	Dest Seq#	Next Hop	Hop Count	Freshness
1	3	136	2	2	Fresh
2	3	136	3	1	Fresh
3	1	25	2	2	Fresh
4	-	-	-	-	-
5	-	-	-	-	-

Higher Destination Sequence Number (Dest Seq#) = Fresher route
Example: Seq# 136 is fresher than Seq# 78.

HOW SEQUENCE NUMBERS WORK IN AODV

- Each node maintains its own Sequence Number. It increases every time the node originates any message.
- Destination Sequence Number (Dest Seq#)
Represents the “freshness” of the route to a destination.
- Higher Sequence Number = Fresher (more recent) route.
- Nodes compare sequence numbers to choose the best route. If a node gets a route with a higher Dest Seq#, it updates its routing table.
- Ensures loop-free and up-to-date routing. Outdated routes (lower Seq#) are ignored.

RREP PACKET EXAMPLE

Route Reply (RREP) Packet

- Source: 3 (Destination) → Node that has the fresh route (here Node 3)
- Destination: 1 (Originator) → Node that requested the route (here Node 1)
- Dest Seq#: 136 → Sequence number of the destination route. Higher number = fresher route.
- Hop Count: 1 → Number of hops from this node to destination.
- Lifetime: ... → Time for which the route is valid.

WHY NODE 1 UPDATES ITS ROUTE?

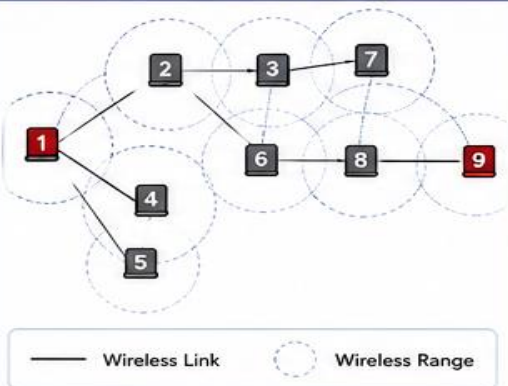
When Node 1 receives the RREP with Dest Seq# = 136, it compares it with the route it has in its table. If the new Sequence Number is higher, it means the route is fresher, so Node 1 replaces the old route with the new one.



AODV – DETAILED EXAMPLE (HOW SEQUENCE NUMBER SELECTS THE BEST ROUTE)

Scenario: Node 1 wants to send data to Node 9. (Node 9 is NOT a direct neighbor of Node 1)

1. NETWORK TOPOLOGY



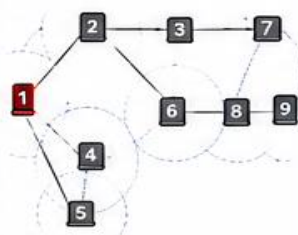
Neighbors of Node 1: 2, 4, 5

KEY POINTS

- Sequence Number (Seq#) shows freshness.
- Higher Seq# = fresher route.
- When multiple routes exist to the destination, the one with the highest destination Seq# is chosen.
- If Seq# is same, then the route with smaller hop count is chosen.
- Old/unused routes are discarded if not refreshed within a time.

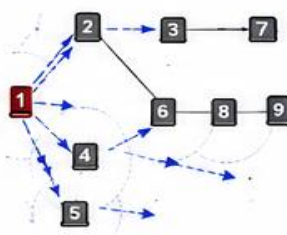
2. ROUTE REQUEST (RREQ) BROADCAST AND FORWARDING

Step 1 (Originated by 1)



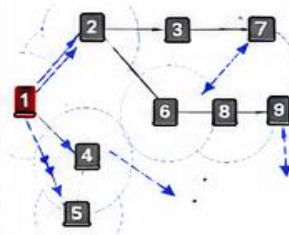
Node 1 broadcasts RREQ
Seq# = 10, Hop Count = 0
to neighbors (2, 4, 5)

Step 2 (Forwarded)



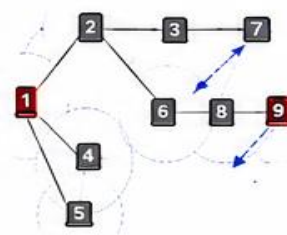
Nodes 2, 4, 5 forward RREQ
to their neighbors.
Hop Count = 1

Step 3 (Forwarded)



RREQ continues...
Hop Count = 2

Step 4 (Forwarded)



RREQ continues...
Hop Count = 3

3. DESTINATION (NODE 9) RECEIVES RREQ FROM TWO DIFFERENT PATHS

Path via Node 8 (first received)
Path: 1 → 2 → 6 → 8 → 9
Hop Count = 4

Node 9 generates RREP-1
Dest Seq# = 100
(First RREP has Seq# 100)

Path via Node 7 (later received)
Path: 1 → 2 → 3 → 7 → 9
Hop Count = 4

Node 9 generates RREP-2
Dest Seq# = 150
(Later RREP has higher Seq#)

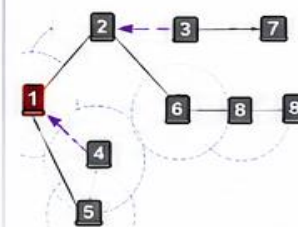
Why different Sequence Numbers?

- Node 9 increases its own Sequence Number every time it generates a RREP.
- First RREP has Seq# = 100.
- Second RREP (generated later) has Seq# = 150.
- Higher Seq# means newer (fresher) route info.
- So, RREP-2 is fresher than RREP-1.

4. RREP REPLY BACK TO SOURCE (NODE 1)

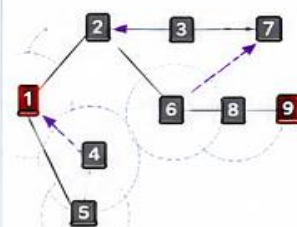
RREP-1 via Node 8 (older)

Path: 9 → 8 → 6 → 2 → 1
Dest Seq# = 100, Hop Count = 4



RREP-2 via Node 7 (newer)

Path: 9 → 7 → 3 → 2 → 1
Dest Seq# = 150, Hop Count = 4



Both RREPs reach Node 1.
Node 1 compares the received routes.

Route	Path	Dest Seq#	Hop Count	Result
RREP-1	1-2-6-8-9	100	4	Older
RREP-2	1-2-3-7-9	150	4	Fresher (Selected)

5. ROUTE SELECTION AT NODE 1

AODV Route Selection Rules (in order):

- Choose the route with the highest Destination Sequence Number.
- If Seq# is same, choose the route with the smallest Hop Count.
- If both are same, choose the one learned first.

Decision:

Node 1 selects RREP-2 route (Seq# = 150) because it is fresher.

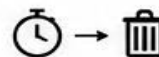
Final Route:

1 → 2 → 3 → 7 → 9
(even though hop count is same)

6. ROUTE USAGE AND DISCARDING UNUSED PATHS

Once Node 1 starts using the selected route:

- Route 1-2-3-7-9 is used for data transmission.
- Route 1-2-6-8-9 (via RREP-1) is kept as an alternate (backup) route for a short time.
- If not used within ACTIVE_ROUTE_TIMEOUT, it is removed from the routing table.
- Only active and fresh routes are maintained.



7. WHY HOP COUNT ALONE IS NOT USED TO SELECT THE ROUTE?



- Hop count only shows the number of hops, not the quality/freshness.
- A path with fewer or same hops may contain stale (old) info.
- Sequence Number guarantees the latest and most accurate route.
- Using only hop count can lead to using broken or outdated paths, causing packet loss and delays.

COMPLETE FLOW SUMMARY



LEGEND: --- RREQ (Route Request) --- RREP (Route Reply) → Data Transmission

Use Sequence Number (freshness) first, Hop Count (distance) second.

Advantages of AODV

- On-Demand Routing. Routes are established only when needed, saving resources.
- Low Memory Usage. Nodes store routes only to active destinations.
- Loop-Free Routes. Sequence numbers ensure up-to-date and loop-free paths.
- Adaptable to Mobility. Suitable for dynamic topologies like MANETs and IoT.
- Scalable for Small to Medium Networks. Works efficiently in environments with moderate node counts.

Limitations of AODV

- High Latency in Route Discovery. Initial delay when no route exists.
- Broadcast Overhead. Flooding RREQ messages consumes bandwidth in dense networks.
- No Multiple Route Support. Maintains only one route per destination.
- Route Maintenance is Reactive. Causes packet loss during route breaks.
- Security Vulnerabilities. Susceptible to blackhole, wormhole, and RREQ flooding attacks.

Wormhole attack

- Wormhole attack is very popular in ad hoc networks.
- IoT connects both stationary and dynamic objects, ranging from wristwatches and refrigerators to vehicles.
- The link that binds these objects is also heterogeneous, may be wired or wireless, and depends on the geographical location.
- Here, the intruder need not compromise any hosts in the network.
- The intruder just captures the data, forwards them to another node, and retransmits them from that node.
- Wormhole attack is very strange and difficult to identify.

Black-Hole Attack

- Which refer to other attack on the level of IoT or Ad-hoc networking, the idea of this attack is to falsely advertise good path to the destination node during the path finding process.
- Malicious node in the network inform the source with fake hope count, to selects its path, the next step refers to drop the received packet by the malicious node.

Selective forwarding attack

- Malicious nodes choose the packets and drop them out; that is, they selectively filter certain packets and allow the rest.
- Dropped packets may carry necessary sensitive data for further processing.

Sinkhole attack

- Sensors, which are left unattended in the network for long periods, are mainly susceptible to sinkhole attack.
- The compromised node attracts the information from all the surrounding nodes.
- Thereby, the intruder posts other attacks, such as selective forward, fabrication, and modification.

Sewage pool attack

- In a sewage pool attack, the malicious user's objective is to attract all the messages of a selected region toward it and then interchange the base station node in order to make selective attacks less effective.

Witch attack

- The malicious node takes advantage of failure of a legitimate node.
- When the legitimate node fails, the factual link takes a diversion through the malicious node for all its future communication, resulting in data loss.

HELLO flood attacks

- In HELLO flood news attacks, every object will introduce itself with HELLO messages to all the neighbours that are reachable at its frequency level.
- A malicious node will cover a wide frequency area, and hence it becomes a neighbour to all the nodes in the network.
- Subsequently, this malicious node will also broadcast a HELLO message to all its neighbours, affecting the availability.
- Flooding attacks cause nonavailability of resources to legitimate users by distributing a huge number of nonsense requests to a certain service.

Addressing all things in IoT

- Spoofing the IP address of virtual machines (VMs) is another serious security challenge.
- Malicious users obtain the IP address of the VMs and implant malicious machines to attack the users of these VMs.
- This enables hacking, and the attackers can access users' confidential data and use it for malicious purposes.

Why Are Virtual Machines (VMs) a Primary Target in IoT Systems?

- Centralized Control Point
 - VMs often host backend services like device managers, brokers, databases, and dashboards.
 - A single VM compromise can affect **hundreds of connected IoT devices**.
- Trusted by All Devices
 - IoT devices trust VMs for updates, instructions, and authentication.
 - Spoofing or compromising a VM allows attackers to send **malicious commands** to IoT nodes.
- Static & Discoverable IPs
 - Cloud-hosted VMs usually have **predictable or static IP addresses**, making them easier to locate and target.
 - Ideal for **IP spoofing** or redirection attacks.
- Sensitive Data Storage
- Resource-Rich and Always-On

Addressing all things in IoT

- The cloud provides on-demand service and supports multitenancy, it is also more prone to DDoS attack.
- As the attacker goes on flooding the target, the target will invest more and more resources into processing the flood request.
- After a certain time, the provider will run out of resources and will be unable to service even legitimate users.
- Unless DLP agents are embedded in the cloud, due to multitenancy and the movement of data from users' control into the cloud environment, the problem of data leakage will also exist.

Distributed denial of service (DDoS)

- DDoS, an attack initiated and continued by some hundreds or even thousands of attackers, starts by populating unwanted traffic packets with enormous size in order to capture and completely deplete memory resources.
- At the same time, the traffic disallows legitimate requests from reaching the Data Center(DC) and also depletes the bandwidth of the DC.
- This eventually leads to unresponsiveness to legitimate requests.
- A denial of service (DoS) or DDoS attack can overwhelm the target's resources, so that authorized users are unable to access the normal services of the cloud.

IP spoof attack

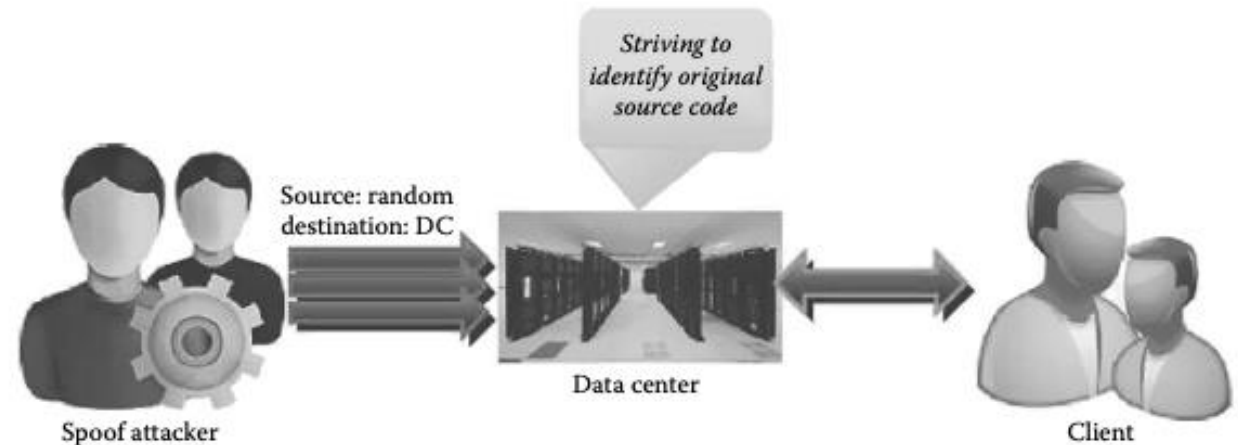
- Spoofing is a type of attack in which the attacker pretends to be someone else in order to gain access to restricted resources or steal information.
- This type of attack can take a variety of different forms; for instance, an attacker can impersonate the IP address of a legitimate user to get into their accounts.
- IP address spoofing, or IP spoofing, refers to the creation of IP packets with a forged source IP address, called spoofing, with the purpose of concealing the identity of the sender or impersonating another computing system.

IP spoof attack

- IP spoofing is most frequently used in DoS attacks.
- In such attacks, the goal is to flood the victim with overwhelming amounts of traffic, and the attacker does not care about receiving responses to the attack packets.
- They have additional advantages for this purpose—they are more difficult to filter, since each spoofed packet appears to come from a different address, and they hide the true source of the attack.
- There are three different types of spoof attacks: impersonation, hiding attack, and reflection attack.

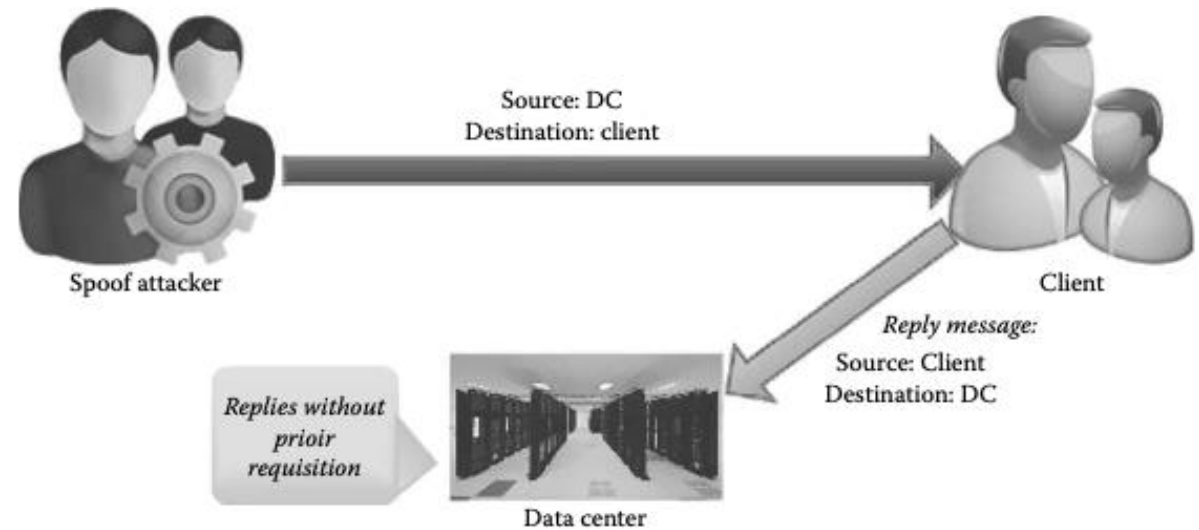
Type I, Hiding attack

- Attackers simultaneously send a large number of spoofed packets with random IP address.
- This creates chaos at the DC regarding which specific packets should be processed as legitimate packets



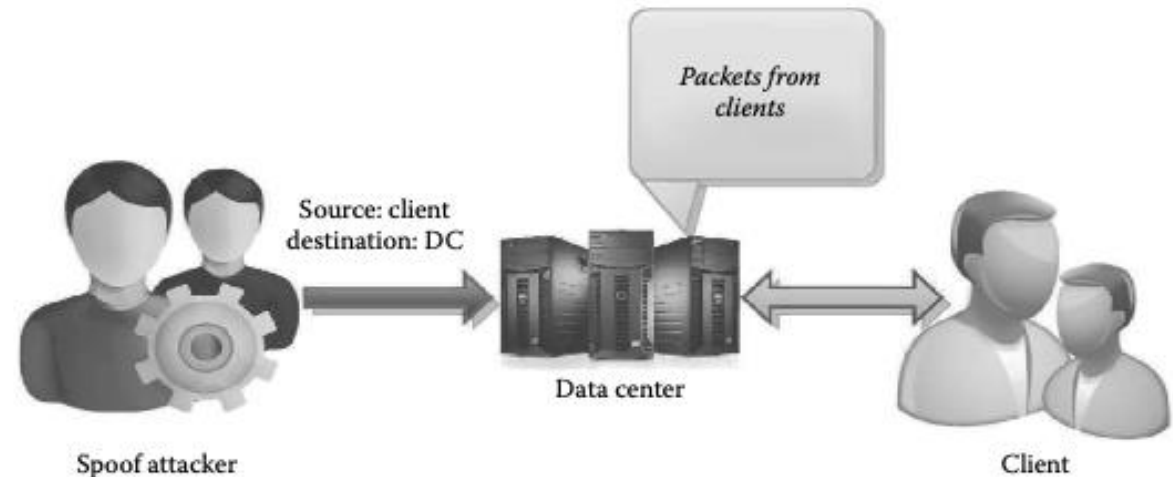
Type II, Reflection attack

- Attackers send spoof packets with the source IP address of the victim to any unknown user.
- This causes unwanted responses to reach the victim from unknown users and increases the flood rate.



Type III, Impersonation attack

- Attackers send spoof packets with the source IP address of any unknown legitimate user and acting as a legitimate user.
- This is equivalent to a man-in-the-middle attack.
- The spoof attacker receives requests from clients, spoofs IP, and forwards the requests to the DC, acting as a legitimate user.
- The responses of the DC are again processed intermediately and sent to the clients.
- This leads to confidentiality issues and data theft or loss at the DC



Spoofing attack continu..

If a proper spoof detection mechanism is not in place, the DC could respond badly, leading to a partial shutdown of services.

- In network-level DDoS, the attackers will try to send invalid requests with the aim of flooding the cloud service provider (CSP); for example, requests for a half-open connection.
- In service-level DDoS, the attacker will be sending requests that seem to be legitimate.
 - Their content will be similar to a request made by a legitimate user.
 - Only their intention is malicious.

Data Center

- A DC is a centralized repository, either physical or virtual, for the storage, management, and dissemination of data and information organized around a particular body of knowledge or pertaining to a particular business.
- A DC is a facility used to house computer systems and associated components and huge storage systems.
- The main purpose of a DC is to run the applications that handle the core business and operational data of the organization.
- Such systems may be proprietary and developed in house by the organization, or bought from enterprise software vendors.

Botnet

- A *botnet* is a collection of Internet-connected computers whose security defences have been breached and control ceded to a malicious party.
- Each such compromised device, known as a “bot,” is created when a computer is penetrated by software from a malware distribution, otherwise known as malicious software.
- The controller of a botnet is able to direct the activities of these compromised computers through communication channels formed by standards-based network protocols such as Internet Relay Chat (IRC) and hypertext transfer protocol (http).

Threats per architecture ...

- Physical security
 - Hardware involved in serving clients must be continuously audited with a safe checkpoint for the sake of hysteresis identification of threats.
- Software security
 - Corruption or modification of application software by threats could affect several clients who depend on that particular application programming interface (API) and related software interfaces.
- Network security
 - Bandwidth attacks such as DoS and DDoS can cause severe congestion the network and also affect normal operations, resulting in communication failure.
- Byzantine failure
 - Byzantine failure is a malicious activity that compromises a server or a set of servers to degrade the performance of the cloud.

Threats per architecture ...

- Eavesdropping
 - An interception of network traffic to gain unauthorized access. It can result in failure of confidentiality.
 - The man in the middle attack is also a category of eavesdropping.
 - The attack sets up a connection with both victims involved in a conversation, making them believe that they are talking directly but infecting the conversation between them.
- Replay attack
 - The attacker intercepts and saves old messages and then sends them later as one of the participants to gain access to unauthorized resources.
- Back door
 - The attacker gains access to the network through bypassing the control mechanisms using a “back door,” such as a modem and asynchronous external connection.

Attacks based on components

- The IoT connects “everything” through the Internet.
- These things are heterogeneous in nature, communicating sensitive data over a distance.
- Apart from attenuation, theft, loss, breach, and disaster, data can also be fabricated and modified by compromised sensors.
- Verification of the end user at the entry level is mandatory; distinguishing between humans and machines is extremely important.
- Different types of Completely Automated Public Turing test to tell Computers and Humans Apart (CAPTCHA) help in this fundamental discrimination.

Attacks based on components

